

臺中市政府衛生局 函

收/發文日期 115. 7. 21

地址：420206臺中市豐原區中興路136號

承辦人：科員 莊小禾

收/發文日期 115. 7. 22

電話：04-22289111#70111

電子信箱：htbcm02005@taichung.gov.tw

受文者：霧峰澄清醫院

發文日期：中華民國115年7月21日

發文字號：中市衛醫字第1150086190號

速別：普通件

密等及解密條件或保密期限：

附件：如說明三（紙本受文者請至本局公文大附件系統下載，網址：<https://annexf.hbtc.gov.tw?C=HfChtX>，公文文號：141150086190 驗證碼：M25T8L）
(387140000I_1150086190_ATTACH1.pdf、387140000I_1150086190_ATTACH2.pdf)

主旨：轉知衛生福利部「醫院個人資料檔案安全查核表」及「醫院個人資料檔案安全自主檢查表」，請貴院落實自主檢查，請查照。

說明：

- 一、依據衛生福利部115年7月15日衛部醫字第1151666916號函辦理。
- 二、為維護醫院個人資料檔案安全，請貴院定期進行醫院個人資料檔案安全自主檢查，並填寫醫院個人資料檔案安全自主檢查表，若發生個資事故，亦請填寫醫院個人資料檔案安全自主檢查表。
- 三、檢附醫院個人資料檔案安全自主檢查表（醫院填寫）及（個資事故調查用，醫院填寫）各1份，紙本受文者請至本局公文大附件系統下載，網址：<https://annexf.hbtc.gov.tw?C=HfChtX>，公文文號：141150086190 驗證碼：M25T8L。

主
辦

協
辦

資
訊

張
景
然

115.7.22

電子
文
騎

0

醫院個人資料檔案安全自主檢查表

（醫院填寫）

醫院名稱：				
保有個資筆數：				
填表日期： 年 月 日				
查核項目	檢查內容	檢查結果	說明	備註
1.個人資料檔案安全維護計畫 （醫院個人資料檔案安全維護計畫實施辦法第5條）	1.1 是否訂定「個人資料檔案安全維護計畫」（以下簡稱安全維護計畫）？	☐ 符合 ☐ 不符合 ☐ 不適用		1. 請提出個人資料檔案安全維護計畫或相關文件。 2. 總床數未達一百床者，得勾選不適用。
	1.2 安全維護計畫最新版本是否已報直轄市、縣（市）主管機關備查	☐ 符合 ☐ 不符合 ☐ 不適用		1. 請提出最新版本之安全維護計畫，及備查證明文件。 2. 總床數未達一百床者，得勾選不適用。
2.配置管理之人員及相當資源 （個人資料保護法施行細則第12條第2項第1款；醫院個人資料檔案安全維護計畫實施辦法第4條）	2.1 是否設有個人資料管理單位或適當組織，並投入相當資源？	☐ 符合 ☐ 不符合 ☐ 不適用		請提出個資管理單位組織圖、分工或相關辦法，並說明個資窗口所協助之各項個資保護工作事項，例如：參與會議、盤點及風險評鑑工作、事件處理等。
	2.2 前述個人資料管理單位或適當組織，是否包含指定專責人員，負責規劃、訂定、修正及執行安全維護計畫，並定期向醫院提出報告？	☐ 符合 ☐ 不符合 ☐ 不適用		1. 請檢附人員名冊，以及最近一次報告書。 2. 總床數未達一百床者，得勾選不適用。
3.界定個人資料之範圍 （個人資料保護法施行細則第12條第2項第	3.1 是否定期清查其所保有之個人資料檔案及其蒐集、處理或利用個人資料之作業	☐ 符合 ☐ 不符合 ☐ 不適用		請提出個人資料檔案盤點清冊及個人資料作業流程說明。

2款； 醫院個人資料檔案安全維護計畫實施辦法第7條)	流程，據以建立個人資料檔案清冊及個人資料作業流程說明文件？			
	3.2 經檢視發現資料無保存必要時，是否刪除、銷毀、停止蒐集、處理、利用或為其他適當之處置？	☐ 符合 ☐ 不符合 ☐ 不適用		請說明定期檢視有無非屬特定目的必要範圍內之個資、特定目的消失或期間屆滿而無保存必要個資之頻率及相關作業流程。
4.個人資料之風險評估及管理機制 (個人資料保護法施行細則第12條第2項第3款)	4.1 是否定期評估個人資料作業流程之風險，並訂定適當之管控及因應措施？	☐ 符合 ☐ 不符合 ☐ 不適用		請提出風險評估及管理機制之相關佐證資料，例如：風險評估報告、風險處理計畫等。
5.個人資料蒐集、處理、利用作業 (個人資料保護法施行細則第12條第2項第5款； 醫院個人資料檔案安全維護計畫實施辦法第8條、第9條、第10條； 電子病歷製作及管理辦法第6條、第7條、第8條、第9條)	5.1 個人資料蒐集、處理是否具備特定目的並具有法定要件？	☐ 符合 ☐ 不符合 ☐ 不適用		1. 請提出合法蒐集、處理個資之佐證資料，例如：最新個資盤點資料，皆已識別個資蒐集、處理之法定要件。 2. 個資蒐集、處理之法定要件請參考：個人資料保護法第15條（公立醫院）、第19條（私立醫院、醫療法人醫院及其他法人附設醫院）。
	5.2 個人資料之利用，是否符合特定目的之範圍？	☐ 符合 ☐ 不符合 ☐ 不適用		請提出合法利用個資之佐證資料，例如：最新個資盤點資料，皆已識別個資的利用為符合特定目的範圍。
	5.3 目的外利用是否符合法定要件？	☐ 符合 ☐ 不符合 ☐ 不適用		1. 如有目的外利用，請提出其符合之法定要件之佐證資料。

			2. 如無目的外利用，可勾選不適用。 3. 個資目的外利用之法定要件請參考：個人資料保護法第16條（公立醫院）、第20條（私立醫院、醫療法人醫院及其他法人附設醫院）。
5.4 是否履行告知義務？若未履行告知義務，是否符合免告知之情形？	☐ 符合 ☐ 不符合 ☐ 不適用		1. 請提出告知同意書或相關佐證，並說明免告知之法規依據。 2. 應告知事項及免告知之情形，請參考個人資料保護法第8條、第9條。
5.5 委託他人蒐集、處理或利用個人資料時，是否於委託契約或相關文件明確約定適當之監督事項及方式，並定期確認及記錄確認受託者執行狀況？	☐ 符合 ☐ 不符合 ☐ 不適用		1. 請提出個資委外之廠商清單、合約文件，以及對委外廠商之查核紀錄、缺失追蹤情形等等佐證資料。 2. 委託建置、管理電子病歷資訊系統者，亦應檢附： (1) 受託機構通過中央主管機關認可之資訊安全標準驗證之證明文件； (2) 依電子病歷製作及管理辦法第9條報直轄市、縣（市）主管機關備查之紀錄。

	5.6 進行個人資料國際傳輸前，是否檢視及遵循衛生福利部限制國際傳輸之命令或處分？	☐ 符合 ☐ 不符合 ☐ 不適用		1. 請提出進行檢視之說明，如無國際傳輸，可勾選不適用。 2. 電子病歷運用雲端服務或委託受託機構提供雲端服務者，請說明雲端服務之資料儲存地點，如為我國境外者，請提出經中央主管機關核准之證明文件。
6.事故之預防、通報及應變機制 (個人資料保護法施行細則第12條第2項第4款；醫院個人資料檔案安全維護計畫實施辦法第14條、電子病歷製作及管理辦法第3條、第5條)	6.1 是否已訂定通報及應變程序？	☐ 符合 ☐ 不符合 ☐ 不適用		1. 請提出個資事故預防、通報及應變機制之管理文件。 2. 實施電子病歷者，請提出電子病歷系統安全事故處理程序。
	6.2 事故發生後，是否即時採取有效應變措施？	☐ 符合 ☐ 不符合 ☐ 不適用		1. 近五年如有發生個資事故或電子病歷系統安全事故，請提出應變措施紀錄（包含事實、影響、已採取之因應措施）。 2. 五年未發生事故者，請勾選不適用。
	6.3 事故發生時，是否於時限內通報應通報機關？	☐ 符合 ☐ 不符合 ☐ 不適用		1. 近五年如有發生個資事故或電子病歷系統安全事故，請提出通報紀錄。 2. 近五年未發生事故者，請勾選不適用。
	6.4 事故發生後，是	☐ 符合		1. 近五年如有發生個資事故或電子

	否即時以適當方式通知當事人？	☐ 不符合 ☐ 不適用		病歷系統安全事故，請提出通知當事人紀錄及佐證資料（包含通知對象、方式、內容、時間）。 2. 近五年未發生事故者，請勾選不適用。
	6.5 事故發生後，是否研議並採取避免事故再度發生之改進措施？	☐ 符合 ☐ 不符合 ☐ 不適用		1. 近五年如有發生個資事故，請提出避免類似事故再次發生之矯正及預防機制。 2. 近五年如有發生電子病歷系統安全事故，請提出檢討及修正措施之紀錄。 3. 近五年未發生事故者，請勾選不適用。
7. 資料安全管理及人員管理 （個人資料保護法施行細則第12條第2項第6款；醫院個人資料檔案安全維護計畫實施辦法第8條、第11條；電子病歷製作及管理辦法第3條）	7.1 是否依業務作業需要，規範個人資料蒐集、處理、利用及其他相關流程之負責人員，設定所屬人員接觸個人資料之權限，並定期檢視其必要性？	☐ 符合 ☐ 不符合 ☐ 不適用		1. 請提出權限設定規範、權限申請及審查紀錄。 2. 實施電子病歷者，請提出權限控管機制（含電子病歷製作、存取、增刪、查閱、複製、傳輸及其他使用權限之管控）及近五年紀錄。
	7.2 是否與所屬人員約定保密義務？	☐ 符合 ☐ 不符合 ☐ 不適用		請提出與所屬人員約定保密之佐證資料，例如：保密切結書、個資保密條款等。
	7.3 人員離職時，是否取消其原在職之存取權限，並要求離職人員將執行業務所持	☐ 符合 ☐ 不符合 ☐ 不適用		請提出離職人員權限異動及文件資料返還之佐證，例如：離職確認單、交接清單等。

	有之文件、資料辦理交接，不得攜離使用？			
	7.4 傳輸個人資料時，是否依不同傳輸方式，採取適當之安全措施？	☐ 符合 ☐ 不符合 ☐ 不適用		1. 請提出對外傳送個資檔案之相關規範，以及執行安全措施之佐證，例如：資通訊系統網際網路傳輸個人資料之安全加密機制。 2. 實施電子病歷者，請提出傳輸加密機制及近五年紀錄；國際傳輸電子病歷者，應提出符合國際標準組織通用加密機制之證明。
8. 認知宣導及教育訓練 (個人資料保護法施行細則第12條第2項第7款、醫院個人資料檔案安全維護計畫實施辦法第12條)	8.1 是否定期對實施所屬人員之個人資料保護與管理認知宣導及教育訓練，使所屬人員明瞭個人資料保護相關法令規定、責任範圍、作業程序及應遵守之相關措施？	☐ 符合 ☐ 不符合 ☐ 不適用		請提出對所屬人員辦理教育訓練之佐證，例如：訓練教材、出席紀錄及課後評量結果等。
9. 設備安全管理措施 (個人資料保護法施行細則第12條第2項第8款；醫院個人資料檔案安全維護計畫實施辦法第13條、第13-1條；電子病歷製作及管理辦法第3條、第4條、第15條)	9.1 是否依據作業內容及環境之不同，訂定各類設備或儲存媒體之使用規範，並據以落實？	☐ 符合 ☐ 不符合 ☐ 不適用		1. 請提出各類設備或儲存媒體之使用規範，以及落實之佐證，例如：進出入登記簿、系統主機、防火牆、個人電腦等設備之定期檢查及維護紀錄。 2. 實施電子病歷者，請提出標準作業機制（包括：系統建置、

				維護及稽核之標準作業程序)及近五年紀錄。
9.2 有無制定資料銷毀程序，並依規定銷毀資料？	☐ 符合 ☐ 不符合 ☐ 不適用			1. 請提出資料銷毀程序，包括電腦、自動化機器或其他儲存媒介物於報廢、汰換或轉作其他用途時，確保所含個人資料完全移除或清除之程序。 2. 請提出落實銷毀程序之紀錄，例如資料銷毀紀錄表冊。
9.3 個人資料有加密之必要者，於蒐集、處理或利用時，是否採取適當之加密措施或配置安全防護系統？	☐ 符合 ☐ 不符合 ☐ 不適用			請說明資料加密措施或其他安全防護措施，例如對資料庫加密、個資檔案設置開啟密碼。
9.4 個人資料有備份之必要者，是否對備份資料採取適當之保護措施？	☐ 符合 ☐ 不符合 ☐ 不適用			1. 請提出資料備份機制相關規範制度文件。 2. 實施電子病歷者，請提出系統安全機制（包括：確保系統安全、時間正確、系統備援與資料備份及其他保護措施）及近五年紀錄。
9.5 蒐集、處理或利用個人資料之資通訊系統，是否採行使用者身分確認及保護機制？	☐ 符合 ☐ 不符合 ☐ 不適用			1. 請說明使用者身分認證機制，並提出相關佐證，例如：帳號權限清查紀錄單。 2. 實施電子病歷者，請提出使用者身分確認機制

			及近五年紀錄。 3. 若無使用資通訊系統者，請勾選「不適用」。
9.6 蒐集、處理或利用個人資料之資通訊系統，是否採行個人資料顯示之隱碼機制？	☐ 符合 ☐ 不符合 ☐ 不適用		1. 請說明個人資料顯示之隱碼機制，並提出相關佐證紀錄，例如：提供系統畫面截圖。 2. 實施電子病歷者，請提出個資隱碼或其他適當保護措施之機制及近五年紀錄。 3. 若無使用資通訊系統者，請勾選「不適用」。
9.7 蒐集、處理或利用個人資料之資通訊系統，是否採行個人資料檔案及資料庫之存取控制與保護監控措施？	☐ 符合 ☐ 不符合 ☐ 不適用		1. 請說明個人資料檔案及資料庫之存取控制與保護監控措施，例如：存取日誌留存、分析及告警機制。 2. 實施電子病歷者，請提出系統使用及資料存取監控措施說明，及近五年紀錄。 3. 若無使用資通訊系統者，請勾選「不適用」。
9.8 蒐集、處理或利用個人資料之資通訊系統，是否採行防止外部網路入侵對策？	☐ 符合 ☐ 不符合 ☐ 不適用		1. 請說明防止外部網路入侵對策，例如：設置防火牆、設置入侵偵測和防禦系統（IDS/IPS）等。 2. 實施電子病歷者，請提出防範網路入侵之機制及近五年紀錄。

			3. 若無使用資通訊系統者，請勾選「不適用」。
9.9 蒐集、處理或利用個人資料之資通訊系統，是否採行非法或異常使用行為之監控與因應機制？	☐ 符合 ☐ 不符合 ☐ 不適用		1. 請提出非法或異常使用行為之監控與因應機制。 2. 實施電子病歷者，請提出非法或異常使用之因應措施之機制及近五年紀錄。 3. 若無使用資通訊系統者，請勾選「不適用」。
9.10 電子病歷系統有無訂定系統開發、上線、維護及應用軟體之驗證確認程序，並據以落實？	☐ 符合 ☐ 不符合 ☐ 不適用		1. 請提出系統開發、上線、維護及應用軟體之驗證確認程序及近五年執行紀錄。 2. 若無實施電子病歷者，請勾選「不適用」。
9.11 電子病歷運用雲端服務或委託受託機構提供雲端服務者，是否確認雲端服務者通過資訊安全標準驗證，且採取風險控管措施、避免醫療業務中斷措施、停止或終止服務時資料移轉返還機制？	☐ 符合 ☐ 不符合 ☐ 不適用		1. 請提出雲端服務者通過中央主管機關認可之資訊安全標準驗證之證明文件。 2. 請提出雲端服務之風險管控措施、避免醫療業務中斷措施、監督措施及停止或終止雲端服務時資料移轉機制，及其相關紀錄。 3. 實施電子病歷，但無運用雲端服務或委託受託機構提供雲端服務者，請勾選不適用。
9.12 蒐集、處理或利用個人資料之資通訊系統，是否採取防止外部網路入侵對策及	☐ 符合		1. 請提出防止外部網路入侵對策及

	用個人資料之資通訊系統之防止外部網路入侵對策及非法或異常使用行為之監控與因應機制，是否定期演練及檢討改善？	☐ 不符合 ☐ 不適用		非法或異常使用行為之監控與因應機制進行演練或檢討，例如針對系統進行演練作業或對防火牆政策進行檢討等。 2. 若無使用資通訊系統者，請勾選「不適用」。
10. 資料安全稽核機制 (個人資料保護法施行細則第12條第2項第9款；醫院個人資料檔案安全維護計畫實施辦法第18條；電子病歷製作及管理辦法第3條)	10.1 是否指定資料安全評核之查核人員，定期評核安全維護計畫之執行情形及成效，並將評核結果，向醫院提出報告？	☐ 符合 ☐ 不符合 ☐ 不適用		1. 請提出資料安全稽核機制之作法，且應包含稽核之頻率及執行方式，並請提出評核報告。 2. 總床數一百床以上者，應每年評核，且查核人員與安全維護計畫之專責人員不得為同一人。
	10.2 依前項評核結果發現計畫不符法令或不符法令之虞者，是否立即改善？	☐ 符合 ☐ 不符合 ☐ 不適用		請提出持續改善之作法，例如矯正單/追蹤紀錄等檢視或修正之紀錄。
11. 使用紀錄、軌跡資料及證據保存 (個人資料保護法施行細則第12條第2項第10款；醫院個人資料檔案安全維護計畫實施辦法第15條；電子病歷製作及管理辦法第13條、第14條、第16條、第17條)	11.1 是否留存個人資料使用紀錄、軌跡資料及其他證據資料？	☐ 符合 ☐ 不符合 ☐ 不適用		1. 請提供個人資料使用紀錄、自動化機器設備之軌跡資料及其他相關之證據資料之保存紀錄。 2. 總床數一百床以上者，紀錄應留存至少六個月。
	11.2 實施電子病歷者，有無於病歷保存期間內，保存電子病歷之完整紀錄？	☐ 符合 ☐ 不符合 ☐ 不適用		1. 請提出醫療法第70條第1項所定病歷保存期間內，電子病歷存取、增刪、查閱、複製與其他相關事

				項，及其執行人員、時間與內容之完整紀錄。 2. 電子病歷移轉由承接者保存者，請提出近五年內移轉紀錄。 3. 銷毀電子病歷或原件者，請提出近五年內之銷毀紀錄。
12. 個人資料安全維護之整體持續改善 （個人資料保護法施行細則第12條第2項第11款；醫院個人資料檔案安全維護計畫實施辦法第17條）	12.1 是否每年參酌安全維護計畫執行狀況、技術發展、法令修正或其他因素，檢視所定安全維護計畫之合宜性，必要時並予以修正？	☐ 符合 ☐ 不符合 ☐ 不適用		1. 請提出個人資料管理或安全維護辦法以及完整之版本資訊（安全維護計畫），包含但不限於日期、提報人及核定人等相關資訊。 2. 總床數未達一百床者，得勾選不適用。
13. 業務終止後個人資料處理方法 （醫院個人資料檔案安全維護計畫實施辦法第16條）	13.1 是否訂定業務終止後，銷毀、移轉、刪除、停止處理或利用個人資料之措施？	☐ 符合 ☐ 不符合 ☐ 不適用		請提出業務終止後，規範個人資料處理方法之程序文件。
	13.2 業務終止後，是否對個人資料處理方法之措施製作紀錄，並保存至少5年？	☐ 符合 ☐ 不符合 ☐ 不適用		1. 請提出業務終止後，個人資料處理方法紀錄之留存情形。 2. 如無業務終止者，請勾選不適用。
受檢醫院簽章：				

填表說明：

一、檢查結果欄：依檢查實際狀況，參考相關佐證資料填具查核結果。

（一）符合：實際作業已依檢查內容訂定相關規範，並已有相關實作紀錄，或已建立標準規範而尚未有實際作業。

(二) 不符合：未完全依檢查內容要求訂定相關程序，或未完全依相關程序執行並產生實作紀錄；並請於說明欄儘可能詳述未符合之情形與樣態。

(三) 不適用：實際作業排除檢查內容之適用。

二、說明欄位：應記錄檢查之參考佐證資料或簡述實際作業狀況。

三、法源依據：

(一) 個人資料保護法、個人資料保護法施行細則。

(二) 醫院個人資料檔案安全維護計畫實施辦法。

(三) 醫療機構電子病歷製作及管理辦法。

附錄一：相關法令

一、個人資料保護法

第一章 總則

第1條

為規範個人資料之蒐集、處理及利用，以避免人格權受侵害，並促進個人資料之合理利用，特制定本法。

第1-1條

本法之主管機關為個人資料保護委員會。

第1-2條

中央及地方各級政府應致力配合推動達成本法立法目的之具體措施，確保其所轄公務機關及所管非公務機關，於執行職務及業務時遵守本法規定，共同建構安全可信賴之個人資料保護環境。

為落實個人資料保護相關事項，主管機關得召開個人資料保護政策推進會議；其運作方式及其他相關事項之辦法，由主管機關定之。

第2條

本法用詞，定義如下：

- 一、個人資料：指自然人之姓名、出生年月日、國民身分證統一編號、護照號碼、特徵、指紋、婚姻、家庭、教育、職業、病歷、醫療、基因、性生活、健康檢查、犯罪前科、聯絡方式、財務情況、社會活動及其他得以直接或間接方式識別該個人之資料。
- 二、個人資料檔案：指依系統建立而得以自動化機器或其他非自動化方式檢索、整理之個人資料之集合。
- 三、蒐集：指以任何方式取得個人資料。
- 四、處理：指為建立或利用個人資料檔案所為資料之記錄、輸入、儲存、編輯、更正、複製、檢索、刪除、輸出、連結或內部傳送。
- 五、利用：指將蒐集之個人資料為處理以外之使用。
- 六、國際傳輸：指將個人資料作跨國（境）之處理或利用。
- 七、公務機關：指依法行使公權力之中央或地方機關或行政法人。
- 八、非公務機關：指前款以外之自然人、法人或其他團體。
- 九、當事人：指個人資料之本人。

第3條

當事人就其個人資料依本法規定行使之下列權利，不得預先拋棄或以特約限制之：

- 一、查詢或請求閱覽。
- 二、請求製給複製本。
- 三、請求補充或更正。

四、請求停止蒐集、處理或利用。

五、請求刪除。

第4條

受公務機關或非公務機關委託蒐集、處理或利用個人資料者，於本法適用範圍內，視同委託機關。

第5條

個人資料之蒐集、處理或利用，應尊重當事人之權益，依誠實及信用方法為之，不得逾越特定目的之必要範圍，並應與蒐集之目的具有正當合理之關聯。

第6條

有關病歷、醫療、基因、性生活、健康檢查及犯罪前科之個人資料，不得蒐集、處理或利用。但有下列情形之一者，不在此限：

一、法律明文規定。

二、公務機關執行法定職務或非公務機關履行法定義務必要範圍內，且事前或事後有適當安全維護措施。

三、當事人自行公開或其他已合法公開之個人資料。

四、公務機關或學術研究機構基於醫療、衛生或犯罪預防之目的，為統計或學術研究而有必要，且資料經過提供者處理後或經蒐集者依其揭露方式無從識別特定之當事人。

五、為協助公務機關執行法定職務或非公務機關履行法定義務必要範圍內，且事前或事後有適當安全維護措施。

六、經當事人書面同意。但逾越特定目的之必要範圍或其他法律另有限制不得僅依當事人書面同意蒐集、處理或利用，或其同意違反其意願者，不在此限。

依前項規定蒐集、處理或利用個人資料，準用第八條、第九條規定；其中前項第六款之書面同意，準用第七條第一項、第二項及第四項規定，並以書面為之。

第7條

第十五條第二款及第十九條第一項第五款所稱同意，指當事人經蒐集者告知本法所定應告知事項後，所為允許之意思表示。

第十六條第七款、第二十條第一項第六款所稱同意，指當事人經蒐集者明確告知特定目的外之其他利用目的、範圍及同意與否對其權益之影響後，單獨所為之意思表示。

公務機關或非公務機關明確告知當事人第八條第一項各款應告知事項時，當事人如未表示拒絕，並已提供其個人資料者，推定當事人已依第十五條第二款、第十九條第一項第五款之規定表示同意。

蒐集者就本法所稱經當事人同意之事實，應負舉證責任。

第8條

公務機關或非公務機關依第十五條或第十九條規定向當事人蒐集個人資料時，應明確告知當事人下列事項：

- 一、公務機關或非公務機關名稱。
 - 二、蒐集之目的。
 - 三、個人資料之類別。
 - 四、個人資料利用之期間、地區、對象及方式。
 - 五、當事人依第三條規定得行使之權利及方式。
 - 六、當事人得自由選擇提供個人資料時，不提供將對其權益之影響。
- 有下列情形之一者，得免為前項之告知：

- 一、依法律規定得免告知。
- 二、個人資料之蒐集係公務機關執行法定職務或非公務機關履行法定義務所必要。
- 三、告知將妨害公務機關執行法定職務。
- 四、告知將妨害公共利益。
- 五、當事人明知應告知之內容。
- 六、個人資料之蒐集非基於營利之目的，且對當事人顯無不利之影響。

第9條

公務機關或非公務機關依第十五條或第十九條規定蒐集非由當事人提供之個人資料，應於處理或利用前，向當事人告知個人資料來源及前條第一項第一款至第五款所列事項。

有下列情形之一者，得免為前項之告知：

- 一、有前條第二項所列各款情形之一。
 - 二、當事人自行公開或其他已合法公開之個人資料。
 - 三、不能向當事人或其法定代理人為告知。
 - 四、基於公共利益為統計或學術研究之目的而有必要，且該資料須經提供者處理後或蒐集者依其揭露方式，無從識別特定當事人者為限。
 - 五、大眾傳播業者基於新聞報導之公益目的而蒐集個人資料。
- 第一項之告知，得於首次對當事人為利用時併同為之。

第10條

公務機關或非公務機關應依當事人之請求，就其蒐集之個人資料，答覆查詢、提供閱覽或製給複製本。但有下列情形之一者，不在此限：

- 一、妨害國家安全、外交及軍事機密、整體經濟利益或其他國家重大利益。
- 二、妨害公務機關執行法定職務。
- 三、妨害該蒐集機關或第三人之重大利益。

第11條

公務機關或非公務機關應維護個人資料之正確，並應主動或依當事人之請求更正或補充之。

個人資料正確性有爭議者，應主動或依當事人之請求停止處理或利用。但因執行職務或業務所必須，或經當事人書面同意，並經註明其爭議者，不在此限。

個人資料蒐集之特定目的消失或期限屆滿時，應主動或依當事人之請求，刪除、停

止處理或利用該個人資料。但因執行職務或業務所必須或經當事人書面同意者，不在此限。

違反本法規定蒐集、處理或利用個人資料者，應主動或依當事人之請求，刪除、停止蒐集、處理或利用該個人資料。

因可歸責於公務機關或非公務機關之事由，未為更正或補充之個人資料，應於更正或補充後，通知曾提供利用之對象。

第 12 條

公務機關或非公務機關知悉所保有之個人資料被竊取、竄改、毀損、滅失或洩漏時，應通知當事人。

前項情形符合一定通報範圍者，公務機關或非公務機關應通報下列機關：

- 一、公務機關：向主管機關及依第二十一條之一第一項規定收受其實施情形之機關通報。
- 二、非公務機關：向主管機關通報。主管機關受理通報後，並轉知其目的事業主管機關。

第一項情形，公務機關或非公務機關應採取即時有效之應變措施，防止事故之擴大，及記載相關事實、影響、已採取之因應措施，並保存相關紀錄，以備主管機關查驗。前三項應通知或通報之內容、方式、時限與通報範圍、應變措施、紀錄保存及其他相關事項之辦法，由主管機關定之。

第 13 條

公務機關或非公務機關受理當事人依第十條規定之請求，應於十五日內，為准駁之決定；必要時，得予延長，延長之期間不得逾十五日，並應將其原因以書面通知請求人。

公務機關或非公務機關受理當事人依第十一條規定之請求，應於三十日內，為准駁之決定；必要時，得予延長，延長之期間不得逾三十日，並應將其原因以書面通知請求人。

第 14 條

查詢或請求閱覽個人資料或製給複製本者，公務機關或非公務機關得酌收必要成本費用。

第二章 公務機關對個人資料之蒐集、處理及利用

第 15 條

公務機關對個人資料之蒐集或處理，除第六條第一項所規定資料外，應有特定目的，並符合下列情形之一者：

- 一、執行法定職務必要範圍內。
- 二、經當事人同意。
- 三、對當事人權益無侵害。

第 16 條

公務機關對個人資料之利用，除第六條第一項所規定資料外，應於執行法定職務必

要範圍內為之，並與蒐集之特定目的相符。但有下列情形之一者，得為特定目的外之利用：

- 一、法律明文規定。
- 二、為維護國家安全或增進公共利益所必要。
- 三、為免除當事人之生命、身體、自由或財產上之危險。
- 四、為防止他人權益之重大危害。
- 五、公務機關或學術研究機構基於公共利益為統計或學術研究而有必要，且資料經過提供者處理後或經蒐集者依其揭露方式無從識別特定之當事人。
- 六、有利於當事人權益。
- 七、經當事人同意。

第 17 條

公務機關應將下列事項公開於電腦網站，或以其他適當方式供公眾查閱；其有變更者，亦同：

- 一、個人資料檔案名稱。
- 二、保有機關名稱及聯絡方式。
- 三、個人資料檔案保有之依據及特定目的。
- 四、個人資料之類別。

第 18 條

公務機關應置個人資料保護長，由機關首長指派適當人員兼任，並配置適當人力及資源，負責統籌推動及督導考核本機關、所屬或所監督公務機關之個人資料保護相關事務。

公務機關應指定專人辦理個人資料檔案安全維護事項，防止個人資料被竊取、竄改、毀損、滅失或洩漏；其安全維護、管理機制、應採取之措施及其他相關事項之辦法，由主管機關定之。

公務機關不得因所屬人員依法執行個人資料保護職務而予以不利之處分或管理措施。主管機關應妥善規劃推動第一項及第二項相關人員之職能訓練，增進其個人資料保護專業知能。

第一項、第二項相關人員之職掌、職能條件、訓練及其他相關事項之辦法，由主管機關定之。

第三章 非公務機關對個人資料之蒐集、處理及利用

第 19 條

非公務機關對個人資料之蒐集或處理，除第六條第一項所規定資料外，應有特定目的，並符合下列情形之一者：

- 一、法律明文規定。
- 二、與當事人有契約或類似契約之關係，且已採取適當之安全措施。
- 三、當事人自行公開或其他已合法公開之個人資料。
- 四、學術研究機構基於公共利益為統計或學術研究而有必要，且資料經過提供者處

理後或經蒐集者依其揭露方式無從識別特定之當事人。

五、經當事人同意。

六、為增進公共利益所必要。

七、個人資料取自於一般可得之來源。但當事人對該資料之禁止處理或利用，顯有更值得保護之重大利益者，不在此限。

八、對當事人權益無侵害。

蒐集或處理者知悉或經當事人通知依前項第七款但書規定禁止對該資料之處理或利用時，應主動或依當事人之請求，刪除、停止處理或利用該個人資料。

第 20 條

非公務機關對個人資料之利用，除第六條第一項所規定資料外，應於蒐集之特定目的必要範圍內為之。但有下列情形之一者，得為特定目的外之利用：

一、法律明文規定。

二、為增進公共利益所必要。

三、為免除當事人之生命、身體、自由或財產上之危險。

四、為防止他人權益之重大危害。

五、公務機關或學術研究機構基於公共利益為統計或學術研究而有必要，且資料經過提供者處理後或經蒐集者依其揭露方式無從識別特定之當事人。

六、經當事人同意。

七、有利於當事人權益。

非公務機關依前項規定利用個人資料行銷者，當事人表示拒絕接受行銷時，應即停止利用其個人資料行銷。

非公務機關於首次行銷時，應提供當事人表示拒絕接受行銷之方式，並支付所需費用。

第 20-1 條

非公務機關保有個人資料檔案者，應辦理安全維護事項，防止個人資料被竊取、竄改、毀損、滅失或洩漏。

前項個人資料檔案安全維護事項、管理機制、應採取之措施及其他相關事項之辦法，由主管機關定之。

第 21 條

非公務機關為國際傳輸個人資料，而有下列情形之一者，主管機關得限制之：

一、涉及國家重大利益。

二、國際條約或協定有特別規定。

三、接受國對於個人資料之保護未有完善之法規，致有損當事人權益之虞。

四、以迂迴方法向第三國（地區）傳輸個人資料規避本法。

第三章之一 行政監督

第一節 對公務機關之監督

第 21-1 條

公務機關應每年向上級機關或監督機關提出個人資料保護管理事項實施情形；無上級機關或監督機關者，依下列各款規定辦理：

- 一、總統府、國家安全會議及五院，向主管機關提出。
- 二、直轄市政府、直轄市議會、縣（市）政府及縣（市）議會，向主管機關提出。
- 三、直轄市山地原住民區公所、直轄市山地原住民區民代表會，向直轄市政府提出；鄉（鎮、市）公所、鄉（鎮、市）民代表會，向縣政府提出。

公務機關應督導及稽核其所屬、所監督之公務機關、所轄鄉（鎮、市）公所、直轄市山地原住民區公所及鄉（鎮、市）民代表會、直轄市山地原住民區民代表會之個人資料保護管理事項實施情形。

依前項規定稽核後，發現受稽核機關實施情形有缺失或待改善者，受稽核機關應向稽核機關提出改善報告，並由稽核機關審查後，連同稽核結果送交主管機關。

稽核機關或主管機關認有必要時，得要求受稽核機關進行說明或調整。

前四項實施情形之必要內容、稽核之頻率、內容與方法、結果之交付、改善報告之提出及其他相關事項之辦法，由主管機關定之。

第 21-2 條

主管機關應定期或不定期稽核公務機關之個人資料保護管理事項實施情形；必要時，得請求前條第二項所定稽核機關協助。

依前項規定稽核後，發現受稽核機關實施情形有缺失或待改善者，受稽核機關應提出改善報告，送交依前條第一項規定收受其實施情形之機關審查後，由該審查機關送交主管機關。

前項審查機關或主管機關認有必要時，得要求受稽核機關進行說明或調整。

前三項稽核之頻率、內容與方法、改善報告之提出及其他相關事項之辦法，由主管機關定之。

依前條及本條參與稽核之人員，對於因執行稽核所知悉或持有之資料，負保密義務。

第 21-3 條

公務機關有違反本法規定之虞時，主管機關得請公務機關提出資料及說明，或派員攜帶執行職務證明文件進行實地檢查，除依法規規定有保密之必要者外，公務機關及其相關人員有配合之義務。

前項實地檢查，必要時得請求第二十一條之一第二項所定稽核機關協助。

參與檢查之人員，對於因執行檢查所知悉或持有之資料，負保密義務。

第 21-4 條

公務機關有違反本法規定之情事者，由主管機關令其限期改正，該公務機關應依限為適當之改正，並應將改正情形以書面答覆主管機關。

公務機關未依前項規定改正者，主管機關得公布其名稱及其違法情形。

公務機關所屬人員未依本法規定辦理者，應按其情節輕重，依相關法令規定予以懲戒、懲處或懲罰。

第 21-5 條

本節之規定，於情報機關不適用之。

第二節 對非公務機關之監督

第 22 條

主管機關認非公務機關有違反本法規定之虞，或為檢視其落實本法情形而認有必要時，得依下列方式進行檢查：

- 一、通知非公務機關或其相關人員陳述意見。
- 二、通知非公務機關或其相關人員提供必要之文書、資料、物品或為其他配合措施。
- 三、自行或會同中央目的事業主管機關、直轄市、縣（市）政府或其他有關機關派員攜帶執行職務證明文件進入檢查，並得令相關人員為必要之說明、配合措施或提供相關證明資料。

前項檢視落實本法情形檢查作業之規劃、評估方式、考量因素、中央目的事業主管機關、直轄市、縣（市）政府或有關機關之協力事項及其他相關事項之辦法，由主管機關定之。

主管機關為第一項檢查時，對於得沒入或可為證據之個人資料或其檔案，得扣留或複製之。對於應扣留或複製之物，得要求其所有人、持有人或保管人提出或交付；無正當理由拒絕提出、交付或抗拒扣留或複製者，得採取對該非公務機關權益損害最少之方法強制為之。

對於依第一項或前項所為之通知、進入、檢查或處分，非公務機關及其相關人員無正當理由不得規避、妨礙或拒絕。

主管機關為第一項第三款檢查時，得率同資訊、電信、法律或其他專業人員共同為之。

參與檢查之人員，對於因執行檢查所知悉或持有之資料，負保密義務，並應注意被檢查者之名譽。

第一項檢查之執行，主管機關於必要時得請求中央目的事業主管機關、直轄市、縣（市）政府或其他相關機關（構）配合採取有效措施或提供協助。

第 23 條

對於前條第三項扣留物或複製物，應加封緘或其他標識，並為適當之處置；其不便搬運或保管者，得命人看守或交由所有人或其他適當之人保管。

扣留物或複製物已無留存之必要，或決定不予處罰或未為沒入之裁處者，應發還之。但應沒入或為調查他案應留存者，不在此限。

第 24 條

非公務機關、物之所有人、持有人、保管人或利害關係人對前二條之要求、強制、扣留或複製行為不服者，得向主管機關聲明異議。

前項聲明異議，主管機關認為有理由者，應立即停止或變更其行為；認為無理由者，得繼續執行。經該聲明異議之人請求時，應將聲明異議之理由製作紀錄交付之。

對於主管機關前項決定不服者，僅得於對該案件之實體決定聲明不服時一併聲明之。但第一項之人依法不得對該案件之實體決定聲明不服時，得單獨對第一項之行為逕

行提起行政訴訟。

第 25 條

非公務機關有違反本法規定之情事者，主管機關除依本法規定裁處罰鍰外，並得為下列處分：

- 一、禁止蒐集、處理或利用個人資料。
- 二、命令刪除經處理之個人資料檔案。
- 三、沒入或令銷毀違法蒐集之個人資料。
- 四、公布違法情形，及其姓名或名稱與負責人。

主管機關為前項處分時，應於防制違反本法規定情事之必要範圍內，採取對該非公務機關權益損害最少之方法為之。

第 26 條

主管機關依第二十二條規定檢查後，未發現有違反本法規定之情事者，經該非公務機關同意後，得公布檢查結果。

第 27 條

（刪除）

第四章 損害賠償及團體訴訟

第 28 條

公務機關違反本法規定，致個人資料遭不法蒐集、處理、利用或其他侵害當事人權利者，負損害賠償責任。但損害因天災、事變或其他不可抗力所致者，不在此限。被害人雖非財產上之損害，亦得請求賠償相當之金額；其名譽被侵害者，並得請求為回復名譽之適當處分。

依前二項情形，如被害人不易或不能證明其實際損害額時，得請求法院依侵害情節，以每人每一事件新臺幣五百元以上二萬元以下計算。

對於同一原因事實造成多數當事人權利受侵害之事件，經當事人請求損害賠償者，其合計最高總額以新臺幣二億元為限。但因該原因事實所涉利益超過新臺幣二億元者，以該所涉利益為限。

同一原因事實造成之損害總額逾前項金額時，被害人所受賠償金額，不受第三項所定每人每一事件最低賠償金額新臺幣五百元之限制。

第二項請求權，不得讓與或繼承。但以金額賠償之請求權已依契約承諾或已起訴者，不在此限。

第 29 條

非公務機關違反本法規定，致個人資料遭不法蒐集、處理、利用或其他侵害當事人權利者，負損害賠償責任。但能證明其無故意或過失者，不在此限。

依前項規定請求賠償者，適用前條第二項至第六項規定。

第 30 條

損害賠償請求權，自請求權人知有損害及賠償義務人時起，因二年間不行使而消滅；自損害發生時起，逾五年者，亦同。

第 31 條

損害賠償，除依本法規定外，公務機關適用國家賠償法之規定，非公務機關適用民法之規定。

第 32 條

依本章規定提起訴訟之財團法人或公益社團法人，應符合下列要件：

- 一、財團法人之登記財產總額達新臺幣一千萬元或社團法人之社員人數達一百人。
- 二、保護個人資料事項於其章程所定目的範圍內。
- 三、許可設立三年以上。

第 33 條

依本法規定對於公務機關提起損害賠償訴訟者，專屬該機關所在地之地方法院管轄。對於非公務機關提起者，專屬其主事務所、主營業所或住所地之地方法院管轄。

前項非公務機關為自然人，而其在中華民國現無住所或住所不明者，以其在中華民國之居所，視為其住所；無居所或居所不明者，以其在中華民國最後之住所，視為其住所；無最後住所者，專屬中央政府所在地之地方法院管轄。

第一項非公務機關為自然人以外之法人或其他團體，而其在中華民國現無主事務所、主營業所或主事務所、主營業所不明者，專屬中央政府所在地之地方法院管轄。

第 34 條

對於同一原因事實造成多數當事人權利受侵害之事件，財團法人或公益社團法人經受有損害之當事人二十人以上以書面授與訴訟實施權者，得以自己之名義，提起損害賠償訴訟。當事人得於言詞辯論終結前以書面撤回訴訟實施權之授與，並通知法院。

前項訴訟，法院得依聲請或依職權公告曉示其他因同一原因事實受有損害之當事人，得於一定期間內向前項起訴之財團法人或公益社團法人授與訴訟實施權，由該財團法人或公益社團法人於第一審言詞辯論終結前，擴張應受判決事項之聲明。

其他因同一原因事實受有損害之當事人未依前項規定授與訴訟實施權者，亦得於法院公告曉示之一定期間內起訴，由法院併案審理。

其他因同一原因事實受有損害之當事人，亦得聲請法院為前項之公告。

前二項公告，應揭示於法院公告處、資訊網路及其他適當處所；法院認為必要時，並得命登載於公報或新聞紙，或用其他方法公告之，其費用由國庫墊付。

依第一項規定提起訴訟之財團法人或公益社團法人，其標的價額超過新臺幣六十萬元者，超過部分暫免徵裁判費。

第 35 條

當事人依前條第一項規定撤回訴訟實施權之授與者，該部分訴訟程序當然停止，該當事人應即聲明承受訴訟，法院亦得依職權命該當事人承受訴訟。

財團法人或公益社團法人依前條規定起訴後，因部分當事人撤回訴訟實施權之授與，致其餘部分不足二十人者，仍得就其餘部分繼續進行訴訟。

第 36 條

各當事人於第三十四條第一項及第二項之損害賠償請求權，其時效應分別計算。

第 37 條

財團法人或公益社團法人就當事人授與訴訟實施權之事件，有為一切訴訟行為之權。但當事人得限制其為捨棄、撤回或和解。

前項當事人中一人所為之限制，其效力不及於其他當事人。

第一項之限制，應於第三十四條第一項之文書內表明，或以書狀提出於法院。

第 38 條

當事人對於第三十四條訴訟之判決不服者，得於財團法人或公益社團法人上訴期間屆滿前，撤回訴訟實施權之授與，依法提起上訴。

財團法人或公益社團法人於收受判決書正本後，應即將其結果通知當事人，並應於七日內將是否提起上訴之意旨以書面通知當事人。

第 39 條

財團法人或公益社團法人應將第三十四條訴訟結果所得之賠償，扣除訴訟必要費用後，分別交付授與訴訟實施權之當事人。

提起第三十四條第一項訴訟之財團法人或公益社團法人，均不得請求報酬。

第 40 條

依本章規定提起訴訟之財團法人或公益社團法人，應委任律師代理訴訟。

第五章 罰則

第 41 條

意圖為自己或第三人不法之利益或損害他人之利益，而違反第六條第一項、第十五條、第十六條、第十九條、第二十條第一項規定，或依第二十一條限制國際傳輸之命令或處分，足生損害於他人者，處五年以下有期徒刑，得併科新臺幣一百萬元以下罰金。

第 42 條

意圖為自己或第三人不法之利益或損害他人之利益，而對於個人資料檔案為非法變更、刪除或以其他非法方法，致妨害個人資料檔案之正確而足生損害於他人者，處五年以下有期徒刑、拘役或科或併科新臺幣一百萬元以下罰金。

第 43 條

中華民國人民在中華民國領域外對中華民國人民犯前二條之罪者，亦適用之。

第 44 條

公務員假借職務上之權力、機會或方法，犯本章之罪者，加重其刑至二分之一。

第 45 條

本章之罪，須告訴乃論。但犯第四十一條之罪者，或對公務機關犯第四十二條之罪者，不在此限。

第 46 條

犯本章之罪，其他法律有較重處罰規定者，從其規定。

第 47 條

非公務機關有下列情事之一者，由主管機關處新臺幣五萬元以上五十萬元以下罰鍰，並令限期改正，屆期未改正者，按次處罰之：

- 一、違反第六條第一項規定。
- 二、違反第十九條規定。
- 三、違反第二十條第一項規定。
- 四、違反依第二十一條規定所為限制國際傳輸之命令或處分。

第 48 條

非公務機關有下列情事之一者，由主管機關令其限期改正，屆期未改正者，按次處新臺幣二萬元以上二十萬元以下罰鍰：

- 一、違反第八條或第九條規定。
- 二、違反第十條、第十一條或第十三條規定。
- 三、違反第十二條第一項或依第四項所定辦法中有關通知之內容、方式或時限之規定。
- 四、違反第二十條第二項或第三項規定。

非公務機關違反第十二條第二項、第三項或依第四項所定辦法中有關通報之內容、方式、時限、應變措施、紀錄保存之規定者，由主管機關處新臺幣二萬元以上二十萬元以下罰鍰，並令其限期改正，屆期未改正者，按次處罰。

非公務機關有下列情事之一者，由主管機關處新臺幣二萬元以上二百萬元以下罰鍰，並令其限期改正，屆期未改正者，按次處新臺幣十五萬元以上一千五百萬元以下罰鍰：

- 一、違反第二十條之一第一項規定。
- 二、違反依第二十條之一第二項所定辦法中有關個人資料檔案安全維護事項、管理機制、應採取措施之規定。
- 三、未依第五十一條之一第三項訂定個人資料檔案安全維護計畫或業務終止後個人資料處理方法。
- 四、違反第五十一條之一第四項所定辦法中有關計畫或處理方法應具備之內容、執行方式或基準之規定。

非公務機關有前項各款情事之一，其情節重大者，由主管機關處新臺幣十五萬元以上一千五百萬元以下罰鍰，並令其限期改正，屆期未改正者，按次處罰。

第 49 條

非公務機關違反第二十二條第四項規定者，由主管機關處新臺幣二萬以上二十萬元以下罰鍰。

第 50 條

非公務機關之代表人、管理人或其他有代表權人，因該非公務機關依前三條規定受罰鍰處罰時，除能證明已盡防止義務者外，應並受同一額度罰鍰之處罰。

第六章 附則

第 51 條

有下列情形之一者，不適用本法規定：

- 一、自然人為單純個人或家庭活動之目的，而蒐集、處理或利用個人資料。
- 二、於公開場所或公開活動中所蒐集、處理或利用之未與其他個人資料結合之影音資料。

公務機關及非公務機關，在中華民國領域外對中華民國人民個人資料蒐集、處理或利用者，亦適用本法。

第 51-1 條

第二十二條第一項、第三項至第七項、第二十三條至第二十六條、第四十七條至第五十條所定對非公務機關之監督管理事項，於主管機關成立之日起六年內，由主管機關報請行政院公告一定範圍之非公務機關，仍由中央目的事業主管機關或直轄市、縣（市）政府管轄。

主管機關應每二年會商相關機關後，報請行政院調整減列前項公告所定一定範圍之非公務機關。

中央目的事業主管機關得指定前二項公告範圍之非公務機關訂定個人資料檔案安全維護計畫或業務終止後個人資料處理方法。

前項計畫、處理方法應具備之內容、執行方式或基準及其他相關事項之辦法，由中央目的事業主管機關比照主管機關依第二十條之一第二項訂定之辦法定之；並得為更嚴格之規定。

第 52 條

第十二條第二項、第二十二條第一項、第三項、第五項、第七項、第二十三條及第二十四條規定由主管機關執行之權限，主管機關得委託或委辦其他機關（構）、行政法人或公益團體辦理。

於前條第一項及第二項公告之範圍內，中央目的事業主管機關或直轄市、縣（市）政府得將第二十二條第一項、第三項、第五項、第七項、第二十三條及第二十四條規定之執行權限，委任所屬機關、委託或委辦其他機關（構）、行政法人或公益團體辦理。

依前二項規定受委託、委辦或委任者，其成員對於因執行相關事務所知悉或持有之資料，負保密義務。

第一項及第二項之公益團體，不得依第三十四條第一項規定接受當事人授與訴訟實施權，以自己之名義提起損害賠償訴訟。

第 53 條

主管機關應訂定特定目的及個人資料類別，提供公務機關及非公務機關參考使用。

第 53-1 條

對主管機關依本法所為之行政處分不服者，直接適用行政訴訟程序。

於第五十一條之一第一項、第二項公告範圍內之非公務機關，對中央目的事業主管機關或直轄市、縣（市）政府依本法所為之行政處分不服者，向主管機關提起訴願。但行政處分係由中央行政機關組織基準法所定之獨立機關所為者，直接適用行政訴

訟程序。

對本法中華民國一百十四年十月十七日修正之條文施行前依本法所為之行政處分不服，於修正施行後提起訴願者，應向主管機關為之。

本法中華民國一百十四年十月十七日修正之條文施行前已受理尚未終結之訴願事件，於修正施行後仍由原受理訴願機關依訴願法規定終結之。

第 54 條

本法中華民國九十九年五月二十六日修正公布之條文施行前，非由當事人提供之個人資料，於本法一百零四年十二月十五日修正之條文施行後為處理或利用者，應於處理或利用前，依第九條規定向當事人告知。

前項之告知，得於本法中華民國一百零四年十二月十五日修正之條文施行後首次利用時併同為之。

未依前二項規定告知而利用者，以違反第九條規定論處。

第 55 條

本法施行細則，由主管機關定之。

第 56 條

本法施行日期，由行政院定之。

本法中華民國九十九年五月二十六日修正公布之現行條文第十九條至第二十二條、第四十三條之刪除及一百十二年五月十六日修正之第四十八條，自公布日施行。

二、個人資料保護法施行細則

第 1 條

本細則依個人資料保護法（以下簡稱本法）第五十五條規定訂定之。

第 2 條

本法所稱個人，指現生存之自然人。

第 3 條

本法第二條第一款所稱得以間接方式識別，指保有該資料之公務或非公務機關僅以該資料不能直接識別，須與其他資料對照、組合、連結等，始能識別該特定之個人。

第 4 條

本法第二條第一款所稱病歷之個人資料，指醫療法第六十七條第二項所列之各款資料。

本法第二條第一款所稱醫療之個人資料，指病歷及其他由醫師或其他之醫事人員，以治療、矯正、預防人體疾病、傷害、殘缺為目的，或其他醫學上之正當理由，所為之診察及治療；或基於以上之診察結果，所為處方、用藥、施術或處置所產生之個人資料。

本法第二條第一款所稱基因之個人資料，指由人體一段去氧核糖核酸構成，為人體控制特定功能之遺傳單位訊息。

本法第二條第一款所稱性生活之個人資料，指性取向或性慣行之個人資料。

本法第二條第一款所稱健康檢查之個人資料，指非針對特定疾病進行診斷或治療之目的，而以醫療行為施以檢查所產生之資料。

本法第二條第一款所稱犯罪前科之個人資料，指經緩起訴、職權不起訴或法院判決有罪確定、執行之紀錄。

第5條

本法第二條第二款所定個人資料檔案，包括備份檔案。

第6條

本法第二條第四款所稱刪除，指使已儲存之個人資料自個人資料檔案中消失。

本法第二條第四款所稱內部傳送，指公務機關或非公務機關本身內部之資料傳送。

第7條

受委託蒐集、處理或利用個人資料之法人、團體或自然人，依委託機關應適用之規定為之。

第8條

委託他人蒐集、處理或利用個人資料時，委託機關應對受託者為適當之監督。

前項監督至少應包含下列事項：

- 一、預定蒐集、處理或利用個人資料之範圍、類別、特定目的及其期間。
- 二、受託者就第十二條第二項採取之措施。
- 三、有複委託者，其約定之受託者。
- 四、受託者或其受僱人違反本法、其他個人資料保護法律或其法規命令時，應向委託機關通知之事項及採行之補救措施。
- 五、委託機關如對受託者有保留指示者，其保留指示之事項。
- 六、委託關係終止或解除時，個人資料載體之返還，及受託者履行委託契約以儲存方式而持有之個人資料之刪除。

第一項之監督，委託機關應定期確認受託者執行之狀況，並將確認結果記錄之。

受託者僅得於委託機關指示之範圍內，蒐集、處理或利用個人資料。受託者認委託機關之指示有違反本法、其他個人資料保護法律或其法規命令者，應立即通知委託機關。

第9條

本法第六條第一項但書第一款、第八條第二項第一款、第十六條但書第一款、第十九條第一項第一款、第二十條第一項但書第一款所稱法律，指法律或法律具體明確授權之法規命令。

第10條

本法第六條第一項但書第二款及第五款、第八條第二項第二款及第三款、第十條但書第二款、第十五條第一款、第十六條所稱法定職務，指於下列法規中所定公務機關之職務：

- 一、法律、法律授權之命令。
- 二、自治條例。

三、法律或自治條例授權之自治規則。

四、法律或中央法規授權之委辦規則。

第 11 條

本法第六條第一項但書第二款及第五款、第八條第二項第二款所稱法定義務，指非公務機關依法律或法律具體明確授權之法規命令所定之義務。

第 12 條

本法第六條第一項但書第二款及第五款所稱適當安全維護措施、第十八條所稱安全維護事項、第十九條第一項第二款及第二十七條第一項所稱適當之安全措施，指公務機關或非公務機關為防止個人資料被竊取、竄改、毀損、滅失或洩漏，採取技術上及組織上之措施。

前項措施，得包括下列事項，並以與所欲達成之個人資料保護目的間，具有適當比例為原則：

- 一、配置管理之人員及相當資源。
- 二、界定個人資料之範圍。
- 三、個人資料之風險評估及管理機制。
- 四、事故之預防、通報及應變機制。
- 五、個人資料蒐集、處理及利用之內部管理程序。
- 六、資料安全管理及人員管理。
- 七、認知宣導及教育訓練。
- 八、設備安全管理。
- 九、資料安全稽核機制。
- 十、使用紀錄、軌跡資料及證據保存。
- 十一、個人資料安全維護之整體持續改善。

第 13 條

本法第六條第一項但書第三款、第九條第二項第二款、第十九條第一項第三款所稱當事人自行公開之個人資料，指當事人自行對不特定人或特定多數人揭露其個人資料。

本法第六條第一項但書第三款、第九條第二項第二款、第十九條第一項第三款所稱已合法公開之個人資料，指依法律或法律具體明確授權之法規命令所公示、公告或以其他方式公開之個人資料。

第 14 條

本法第六條第一項但書第六款、第十一條第二項及第三項但書所定當事人書面同意之方式，依電子簽章法之規定，得以電子文件為之。

第 15 條

本法第七條第二項所定單獨所為之意思表示，如係與其他意思表示於同一書面為之者，蒐集者應於適當位置使當事人得以知悉其內容並確認同意。

第 16 條

依本法第八條、第九條及第五十四條所定告知之方式，得以言詞、書面、電話、簡訊、電子郵件、傳真、電子文件或其他足以使當事人知悉或可得知悉之方式為之。

第 17 條

本法第六條第一項但書第四款、第九條第二項第四款、第十六條但書第五款、第十九條第一項第四款及第二十條第一項但書第五款所稱無從識別特定當事人，指個人資料以代碼、匿名、隱藏部分資料或其他方式，無從辨識該特定個人者。

第 18 條

本法第十條但書第三款所稱妨害第三人之重大利益，指有害於第三人個人之生命、身體、自由、財產或其他重大利益。

第 19 條

當事人依本法第十一條第一項規定向公務機關或非公務機關請求更正或補充其個人資料時，應為適當之釋明。

第 20 條

本法第十一條第三項所稱特定目的消失，指下列各款情形之一：

- 一、公務機關經裁撤或改組而無承受業務機關。
- 二、非公務機關歇業、解散而無承受機關，或所營事業營業項目變更而與原蒐集目的不符。
- 三、特定目的已達成而無繼續處理或利用之必要。
- 四、其他事由足認該特定目的已無法達成或不存在。

第 21 條

有下列各款情形之一者，屬於本法第十一條第三項但書所定因執行職務或業務所必須：

- 一、有法令規定或契約約定之保存期限。
- 二、有理由足認刪除將侵害當事人值得保護之利益。
- 三、其他不能刪除之正當事由。

第 22 條

本法第十二條所稱適當方式通知，指即時以言詞、書面、電話、簡訊、電子郵件、傳真、電子文件或其他足以使當事人知悉或可得知悉之方式為之。但需費過鉅者，得斟酌技術之可行性及當事人隱私之保護，以網際網路、新聞媒體或其他適當公開方式為之。

依本法第十二條規定通知當事人，其內容應包括個人資料被侵害之事實及已採取之因應措施。

第 23 條

公務機關依本法第十七條規定為公開，應於建立個人資料檔案後一個月內為之；變更時，亦同。公開方式應予以特定，並避免任意變更。

本法第十七條所稱其他適當方式，指利用政府公報、新聞紙、雜誌、電子報或其他可供公眾查閱之方式為公開。

第 24 條

公務機關保有個人資料檔案者，應訂定個人資料安全維護規定。

第 25 條

本法第十八條所稱專人，指具有管理及維護個人資料檔案之能力，且足以擔任機關之個人資料檔案安全維護經常性工作之人員。

公務機關為使專人具有辦理安全維護事項之能力，應辦理或使專人接受相關專業之教育訓練。

第 26 條

本法第十九條第一項第二款所定契約或類似契約之關係，不以本法修正施行後成立者為限。

第 27 條

本法第十九條第一項第二款所定契約關係，包括本約，及非公務機關與當事人間為履行該契約，所涉及必要第三人之接觸、磋商或聯繫行為及給付或向其為給付之行為。

本法第十九條第一項第二款所稱類似契約之關係，指下列情形之一者：

一、非公務機關與當事人間於契約成立前，為準備或商議訂立契約或為交易之目的，所進行之接觸或磋商行為。

二、契約因無效、撤銷、解除、終止而消滅或履行完成時，非公務機關與當事人為行使權利、履行義務，或確保個人資料完整性之目的所為之連繫行為。

第 28 條

本法第十九條第一項第七款所稱一般可得之來源，指透過大眾傳播、網際網路、新聞、雜誌、政府公報及其他一般人可得知悉或接觸而取得個人資料之管道。

第 29 條

依本法第二十二條規定實施檢查時，應注意保守秘密及被檢查者之名譽。

第 30 條

依本法第二十二條第二項規定，扣留或複製得沒入或可為證據之個人資料或其檔案時，應掣給收據，載明其名稱、數量、所有人、地點及時間。

依本法第二十二條第一項及第二項規定實施檢查後，應作成紀錄。

前項紀錄當場作成者，應使被檢查者閱覽及簽名，並即將副本交付被檢查者；其拒絕簽名者，應記明其事由。

紀錄於事後作成者，應送達被檢查者，並告知得於一定期限內陳述意見。

第 31 條

本法第五十二條第一項所稱之公益團體，指依民法或其他法律設立並具備個人資料保護專業能力之公益社團法人、財團法人及行政法人。

第 32 條

本法修正施行前已蒐集或處理由當事人提供之個人資料，於修正施行後，得繼續為處理及特定目的內之利用；其為特定目的外之利用者，應依本法修正施行後之規定

為之。

第 33 條

本細則施行日期，由法務部定之。

三、醫院個人資料檔案安全維護計畫實施辦法

第 1 條

本辦法依個人資料保護法（以下簡稱本法）第二十七條第三項規定訂定之。

第 2 條

本辦法適用範圍，為醫院蒐集、處理及利用之病歷或醫療個人資料。

第 3 條

本辦法所稱主管機關：在中央為衛生福利部；在直轄市為直轄市政府；在縣（市）為縣（市）政府。

第 4 條

本辦法用詞，定義如下：

- 一、醫院：指總床數達一百床以上之私立醫院、醫療法人醫院及其他法人附設醫院。
 - 二、所屬人員：指醫院執行業務之過程，接觸個人資料之人員。
 - 三、專責人員：指醫院指定，負責規劃、訂定、修正及執行個人資料檔案安全維護計畫（以下簡稱安全維護計畫），及業務終止後個人資料處理方法與其他相關事項，並應定期向醫院提出報告之人員。
 - 四、查核人員：指醫院指定，負責評核安全維護計畫執行情形及成效之人員。
- 前項第三款與第四款人員，不得為同一人。

第 5 條

醫院應依本辦法規定訂定安全維護計畫，其應載明事項如下：

- 一、個人資料蒐集、處理及利用之內部管理程序。
- 二、個人資料之範圍及項目。
- 三、人員管理及教育訓練。
- 四、設備安全管理。
- 五、個人資料安全事故之預防、通報及應變機制。
- 六、使用紀錄、軌跡資料及證據保存。
- 七、業務終止後，個人資料處理方法。
- 八、個人資料安全維護之整體持續改善方案。
- 九、資料安全管理及稽核機制。

前項安全維護計畫，應報直轄市、縣（市）主管機關備查；修正時，亦同。

第 6 條

前條安全維護計畫，應依醫院業務規模及特性，衡酌經營資源之合理分配，規劃、訂定、檢討或修正安全維護措施，落實個人資料檔案之安全維護及管理，防止個人

資料被竊取、竄改、毀損、滅失或洩漏。

第 7 條

醫院訂定第五條第一項第一款個人資料蒐集、處理及利用之內部管理程序及第二款個人資料之範圍及項目時，應確認蒐集個人資料之特定目的及其必要性，界定所蒐集、處理及利用個人資料之類別或範圍，並定期清查所保有之個人資料現況。

醫院經定期檢視，發現有非屬特定目的必要範圍內之個人資料或特定目的消失、期間屆滿而無保存必要者，應依第五條第一項第八款及醫療法第七十條規定，刪除、銷毀、停止蒐集、處理、利用或為其他適當之處置。

第 8 條

醫院於蒐集個人資料時，應符合前條第一項所定之類別及範圍。

醫院於傳輸個人資料時，應採取必要保護措施；國際傳輸電子病歷時，並應符合醫療機構電子病歷製作及管理辦法之規定。

第 9 條

醫院於蒐集個人資料時，應遵守本法第八條及第九條有關告知義務之規定，並依直接蒐集或間接蒐集，分別訂定告知方式、內容及注意事項，要求所屬人員確實辦理。前項告知，其他法規另有規定者，從其規定。

第 10 條

醫院委託他人蒐集、處理或利用個人資料之全部或一部時，應對受託人依本法施行細則第八條規定為適當之監督，並於委託契約或相關文件中，明確約定其內容。

第 11 條

醫院應依第五條第一項第一款規定，對其所屬人員採取下列措施：

- 一、依據業務作業需要，建立管理機制，設定所屬人員權限，控管其接觸個人資料，並定期確認權限內容之必要性及適當性。
- 二、檢視各相關業務之性質，規範個人資料蒐集、處理、利用及其他相關流程之負責人員。
- 三、要求所屬人員妥善保管個人資料之儲存媒介物，並約定保管及保密義務。
- 四、取消所屬人員離職時之存取權限，並要求將執行業務所持有之文件、資料，辦理交接，不得攜離使用。

第 12 條

醫院應依第五條第一項第三款規定，使所屬人員明瞭個人資料保護相關法令規定、責任範圍、作業程序及應遵守之相關措施。

第 13 條

醫院應依第五條第一項第四款規定，對所持有之個人資料檔案，設置必要之安全設備及防護措施。

前項安全設備及防護措施，應包括下列事項：

- 一、訂定各類設備或儲存媒體之使用規範。
- 二、個人資料內容於蒐集、處理或利用時，訂定並採取適當之加密措施或配置安全

防護系統。

三、個人資料有備份之需要時，訂定備份機制、管理及保護程序。

四、訂定資料之銷毀程序，包括電腦、自動化機器或其他儲存媒介物於報廢、汰換或轉作其他用途時，確保個人資料完全移除或清除，無洩漏之虞。

第 13-1 條

前條個人資料檔案使用資通訊系統蒐集、處理或利用時，應訂定並採取下列資訊安全措施：

一、使用者身分確認及保護措施。

二、個人資料顯示之隱碼措施及使用時機。

三、網際網路傳輸之安全加密措施。

四、個人資料檔案及資料庫之存取控制與保護監控措施。

五、防止外部網路入侵措施。

六、非法或異常使用行為之監控及因應措施。

前項第五款及第六款措施，應定期演練及檢討改善。

第 14 條

醫院應依第五條第一項第五款規定，於發生個人資料被竊取、洩漏、竄改、毀損、滅失或其他侵害事故時迅速處理，以保護當事人之權益。

前項處理應包括下列事項：

一、採取適當之措施，控制事故對當事人造成之損害。

二、查明事故發生原因及損害狀況，以適當方式通知當事人或其法定代理人，並於發現事故時起七十二小時內，以書面通報直轄市、縣（市）主管機關及副知中央主管機關。

三、研議並採取避免事故再度發生之改進措施。

直轄市、縣（市）主管機關就所轄醫院個人資料發生第一項事故之完整處理情形，應按季通報中央主管機關。

直轄市、縣（市）主管機關接受第二項通報後，得依本法第二十二條至第二十五條規定，對該醫院為適當之監督管理措施；中央主管機關認有必要時，得督導直轄市、縣（市）主管機關對於該醫院之相關監督管理機制。

第二項第二款通報紀錄格式及第三項按季通報紀錄格式，規定如附件一及附件二。

第 15 條

醫院應依第五條第一項第六款規定，採行適當措施，留存個人資料使用紀錄、自動化機器設備之軌跡資料或其他相關之證據資料，並於必要時提供說明。

前項紀錄與資料，應至少留存六個月。但法令另有規定者，不在此限。

第 16 條

醫院應依第五條第一項第七款規定，對業務終止後，其保有個人資料，依下列方式為之，並製作紀錄：

一、銷毀：銷毀之方法、時間、地點及證明。

二、移轉：移轉之原因、對象、方法、時間、地點及受移轉對象得保有該項個人資料之合法依據。

三、其他刪除、停止處理或利用個人資料：刪除、停止處理或利用之方法、時間或地點。

前項紀錄，應至少留存五年。但法令另有規定者，不在此限。

第 17 條

醫院應依第五條第一項第八款規定，參酌安全維護計畫執行狀況、技術發展、法令依據修正及其他因素，檢視所定安全維護計畫之合宜性，必要時應予修正。

第 18 條

查核人員應每年評核安全維護計畫之執行情形及成效，並將評核結果，向醫院提出報告。

醫院應依據前項評核結果，責成專責人員檢討、修正安全維護計畫之執行事項。

直轄市、縣（市）主管機關應定期查核第一項評核結果。

第 19 條

本辦法於公立醫院，準用之。

第 20 條

本辦法自發布後六個月施行。

本辦法修正條文自發布日施行。

四、醫療機構電子病歷製作及管理辦法

第一章 總則

第 1 條

本辦法依醫療法（以下簡稱本法）第六十九條規定訂定之。

第 2 條

醫療機構以電子文件方式製作及貯存之病歷（以下簡稱電子病歷），符合本辦法之規定者，得免另以書面方式製作。

第 3 條

醫療機構實施電子病歷者，應建置電子病歷資訊系統（以下簡稱系統），並具備下列管理機制：

一、標準作業機制：系統建置、維護及稽核之標準作業程序。

二、權限管控機制：電子病歷製作、存取、增刪、查閱、複製、傳輸及其他使用權限之管控。

三、緊急應變機制：系統故障之預防、通報、應變、復原及其他緊急應變措施。

四、系統安全機制：確保系統安全、時間正確、系統備援與資料備份及其他保護措施。

五、傳輸加密機制：網路傳輸電子病歷，使用國際標準組織通用之加密機制。

六、安全事故處理機制：因應系統遭侵入、資料洩漏、毀損或其他安全事故之預防、通報與應變、檢討及修正措施。

執行前項各款管理機制，應製作紀錄，妥善保存至少五年。

第4條

前條第一項第四款系統安全機制之其他保護措施，應包括下列事項：

一、使用者身分之確認。

二、個人資料顯示之隱碼或其他適當保護措施。

三、系統開發、上線、維護及應用軟體之驗證確認程序。

四、系統使用及資料存取之監控措施。

五、網路入侵系統之防範措施。

六、非法或異常使用之因應措施。

第5條

醫療機構發生第三條第一項第六款安全事故時，並應以個人資料保護法施行細則第二十二條所定方式及內容，通知當事人或其法定代理人。

前項安全事故影響醫療機構營運或當事人權益時，醫療機構應於知悉事故發生起七十二小時內通報直轄市、縣（市）主管機關。

第6條

第三條第一項系統，醫療機構得委託大專校院、依法登記或立案之法人、機構或團體（以下併稱受託機構）建置及管理之，並由醫療機構負本法及本辦法規定之責任。

前項醫療機構之委託，應訂定書面契約。但有下列情形之一者，得免訂定書面契約：

一、委託所屬醫療法人或其他法人之其他附設醫院。

二、委託所屬學校之其他附設醫院。

三、委託所屬機關設立之其他醫院。

第一項受託機構，應通過中央主管機關認可之資訊安全標準驗證，並有證明文件。

第7條

前條第二項契約，應載明下列事項：

一、委託事項之範圍。

二、受託機構之權利義務。

三、受託機構應遵行第三條至第四條、第八條、第十三條至第十六條規定。

- 四、受託機構利用非自行開發之系統或資源者，其來源及授權證明。
- 五、病人隱私保障及資料保密與安全維護之措施。
- 六、受託機構遵行委託機構訂定之標準作業程序、風險管理、內部控制及稽核制度。
- 七、雙方終止及解除契約之事由及資料處理機制。
- 八、受託機構就委託事項，同意主管機關於指定期間內取得相關文件、資料或報告。
- 九、受託機構就委託事項，發現資通安全異常或缺失時，應立即通知委託機構。
- 十、受託機構就委託事項，不得再委託第三人為之。但經醫療機構同意，並於契約載明再委託事項、期間及再受託者，且不免除原受託機構之義務時，不在此限。
- 十一、其他中央主管機關指定之事項。

第 8 條

醫療機構就系統資料之蒐集、處理與利用及資料庫之使用，運用雲端服務或委託受託機構提供雲端服務時，應依下列規定辦理：

- 一、採取適當風險管控措施。
 - 二、採取避免醫療業務中斷措施。
 - 三、對雲端服務業者進行監督，並得視需要，委託受託機構或其他專業機構協助監督。
 - 四、停止或終止雲端服務時，資料移轉回委託機構或其他雲端服務業者之機制。
- 前項雲端服務之資料儲存地點，應設置於我國境內。但因特殊情形，經中央主管機關核准者，不在此限。
- 第一項提供雲端服務者，應通過中央主管機關認可之資訊安全標準驗證，並有證明文件。

第 9 條

醫療機構實施電子病歷者，應敘明開始實施之日期及範圍，並檢附第六條第二項契約及第三項驗證通過之證明文件，於實施之日起十五日內報直轄市、縣（市）主管機關備查；變更實施範圍、受託機構或停止實施時亦同。

第 10 條

醫療機構實施電子病歷者，於接受醫院評鑑或申報全民健康保險給付時，醫院評鑑或全民健康保險之主管、主辦機關非有特殊理由，不得要求其提供電子病歷之列印或影印本。

第二章 病歷製作及簽章

第 11 條

醫療機構製作電子病歷，應符合下列規定：

- 一、輸入識別碼或其他識別方式，經電腦系統確認其身分及權限相符後，始得進行。

二、增刪電子病歷時，應能與增刪前明顯辨識，並保存個人使用紀錄及日期資料。

三、依本法第六十八條第一項所為之簽名或蓋章，以電子簽章為之。

四、病歷製作後，應於二十四小時內完成電子簽章。

五、電子簽章後，應進行存檔及備份。

醫事人員因故無法於前項第四款時限內完成電子簽章時，應由醫療機構採用醫事機構憑證簽章代替；除有特殊情形外，醫事人員應於事後完成補簽。

第 12 條

電子簽章，除前條第二項規定外，應憑中央主管機關核發之醫事人員憑證為之。但醫療機構訂有符合電子簽章法規定之其他簽章方式者，得依其方式為之。

前條第二項醫事機構憑證與前項醫事人員憑證及其附卡、備用卡之核發、換發、補發，由中央主管機關自行或委託民間團體辦理，並得收取費用；其費額，依醫事憑證收費標準之規定。

第三章 儲存、銷毀及交換

第 13 條

本法第七十條第一項所定病歷保存期間內，電子病歷之存取、增刪、查閱、複製與其他相關事項，及其執行人員、時間與內容，應保存完整紀錄。

第 14 條

醫療機構依本法第七十條第二項規定，將電子病歷移轉由承接者保存時，應將移轉之原因、對象、方法、時間、地點及受移轉對象得保有該電子病歷之合法依據，製作紀錄交由承接者至少保存五年。

第 15 條

醫療機構儲存電子病歷之電腦、自動化機器或其他電子媒介物（以下併稱儲存媒體），於報廢、汰換或轉作其他用途時，應採取適當措施，確保電子病歷資料完全移除或清除，而無洩漏之虞；儲存媒體無法完全移除、清除或可事後還原資料者，應進行實體破壞，使其無法使用。

第 16 條

醫療機構依本法第七十條第二項、第四項銷毀電子病歷時，應記錄銷毀之人員、方法、時間及地點，並保存紀錄至少五年；委外銷毀時，亦同。

執行前項銷毀，應派人全程監視確認已完全銷毀，並拍照存證。

第 17 條

醫療機構得將下列資料，以電子方式轉錄為電子檔案保存；轉錄後，應檢視電子檔

案內容與原件相符，並以醫事機構憑證簽章封存後，報直轄市、縣（市）主管機關備查，始視同電子病歷：

一、依本法或其他醫療法規規定，應以書面同意且併同病歷保存之文件。

二、醫療機構電子病歷實施前既有之紙本病歷。

三、其他依法令規定應併同病歷保存之文件、資料。

前項原件，得免以書面方式保存，且不受本法第七十條第一項保存期間之限制。

醫療機構銷毀第一項原件紙本文件、資料時，應記錄銷毀之明細、方法、時間及地點，並保存紀錄至少五年。

第 18 條

中央主管機關或經中央主管機關認可之機關及公、私立機構，得設置電子病歷交換平臺，供醫療機構進行跨機構電子病歷交換或利用。

醫療機構進行電子病歷交換或利用時，應以前項平臺為之。但第六條第二項但書各款醫療機構使用同一系統者，不在此限。

第一項電子病歷交換格式、簽章與時戳及其他相關事項，由中央主管機關公告之。

第 19 條

醫療機構依前條第一項交換平臺為電子病歷交換或利用時，應經病人同意，始得為之。但病人情況緊急，無法取得或未能及時取得同意者，不在此限。

前項病人為胎兒時，應得其母同意；為限制行為能力人或受輔助宣告之人時，應得其本人及法定代理人或輔助人同意；為無行為能力人或受監護宣告之人時，應得其法定代理人或監護人同意。

第一項病人為無意思能力之成年人，未能依前項規定辦理時，應取得親屬或關係人之同意。

第四章 附則

第 20 條

依本法或其他醫療法規規定，應以書面同意且併同病歷保存之文件，得依電子簽章法之規定，以電子方式為之；並得應相對人要求，交付紙本或以電子方式提供。

第 21 條

電子病歷個人資料之保護，本辦法未規定者，依個人資料保護法、醫院個人資料檔案安全維護計畫實施辦法及其他相關法令之規定。

第 22 條

本辦法中華民國一百十一年七月十八日修正施行前，醫療機構已委託受託機構建置、管理系統者，應自修正施行之日起一年內，依第九條規定辦理。

交付日期：115年3月27日

交付版次：v.1版

本辦法中華民國一百一十一年七月十八日修正施行前，機關及公、私立機構已建置之電子病歷交換平臺，應自修正施行之日起一年內，取得第十八條第一項之認可，並符合第十八條第三項規定。

第 23 條

本辦法自發布日施行。

醫院個人資料檔案安全自主檢查表

(個資事故調查用，醫院填寫)

醫院名稱：				
保有個資筆數：				
填表日期： 年 月 日				
查核項目	檢查內容	檢查結果	說明	備註
1.事故調查與應變 (個人資料保護法施行細則第12條第2項第4款； 醫院個人資料檔案安全維護計畫實施辦法第14條； 電子病歷製作及管理辦法第3條、第5條)	1.1 是否已訂定事故通報及應變程序？	☐ 符合 ☐ 不符合 ☐ 不適用		1. 請提出個資事故預防、通報及應變機制之管理文件。 2. 實施電子病歷者，請提出電子病歷系統安全事故處理程序。
	1.2 本次事故發生後，是否即時採取有效應變措施？	☐ 符合 ☐ 不符合 ☐ 不適用		請提出對本次事故採取應變措施之紀錄及佐證，包含技術面、管理面措施。
	1.3 本次事故發生後，是否於時限內通報應通報機關？	☐ 符合 ☐ 不符合 ☐ 不適用		1. 請提出通報紀錄： (1) 總床數一百床以上醫院發生個資事故，應於發現事故時起72小時內，書面通報直轄市、縣（市）主管機關，副知中央主管機關。 (2) 電子病歷資訊系統發生安全事故，影響醫療機構營運或當事人權益者，應於知悉事故發生起72小時內通報直轄市、縣（市）主管機關。 2. 非屬前項情形者，得勾選不適用，但仍應依中

			央或地方主管機關要求，提供事故發生、調查及處置相關資訊。
	1.4 本次事故發生後，是否即時以適當方式通知當事人？	☐ 符合 ☐ 不符合 ☐ 不適用	請提出通知當事人紀錄及佐證資料（包含通知對象、方式、內容、時間）。
	1.5 是否針對本次事故調查根因，並製作調查及處理報告？	☐ 符合 ☐ 不符合 ☐ 不適用	請提出事故調查及處理報告（包含事故發生機關與關聯機關、事故描述、事故類型分析、受影響個人資料類別及損害評估、通知當事人之情形、所採取應變措施、事故發生原因分析、後續改善作為等）。
	1.6 是否針對本次事故，研議並採取避免事故再度發生之改進措施？	☐ 符合 ☐ 不符合 ☐ 不適用	1. 發生個資事故者，請提出避免類似事故再次發生之矯正及預防機制說明、相關措施執行紀錄。 2. 發生電子病歷系統安全事故者，請提出檢討及修正措施之紀錄。
	1.7 本次事故前，是否曾發生其他事故？		如五年內發生其他個資事故或電子病歷系統安全事故，請說明（包含事實、影響、已採取之因應措施、對主管機關相關處分的遵循情形等）。
2.個人資料檔案安全維護計畫 （醫院個人資料檔案安全維護計畫實施辦法第5條）	2.1是否訂定「個人資料檔案安全維護計畫」（以下簡稱安全維護計畫）？	☐ 符合 ☐ 不符合 ☐ 不適用	1. 請提出個人資料檔案安全維護計畫或相關文件。 2. 總床數未達一百床者，得勾選不適用。

	2.2 安全維護計畫 最新版本是否已報 直轄市、縣（市） 主管機關備查	☐ 符合 ☐ 不符合 ☐ 不適用		1. 請提出最新版本 之安全維護計 畫，及備查證明 文件。 2. 總床數未達一百 床者，得勾選不 適用。
3.配置管理之人員 及相當資源 （個人資料保護法施行 細則第12條第2項第1 款； 醫院個人資料檔案安全 維護計畫實施辦法第4 條）	3.1 是否設有個人 資料管理單位或適 當組織，並投入相 當資源？	☐ 符合 ☐ 不符合 ☐ 不適用		請提出個資管理單位 組織圖、分工或相關 辦法，並說明個資窗 口所協助之各項個資 保護工作事項，例 如：參與會議、盤點 及風險評鑑工作、事 件處理等。
	3.2 前述個人資料 管理單位或適當組 織，是否包含指定 專責人員，負責規 劃、訂定、修正及 執行安全維護計 畫，並定期向醫院 提出報告？	☐ 符合 ☐ 不符合 ☐ 不適用		1. 請檢附人員名 冊，以及最近一 次報告書。 2. 總床數未達一百 床者，得勾選不 適用。
4.界定個人資料之 範圍 （個人資料保護法施行 細則第12條第2項第2 款； 醫院個人資料檔案安全 維護計畫實施辦法第7 條）	4.1 是否定期清查 其所保有之個人資 料檔案及其蒐集、 處理或利用個人資 料之作業流程，據 以建立個人資料檔 案清冊及個人資料 作業流程說明文 件？	☐ 符合 ☐ 不符合 ☐ 不適用		請提出個人資料檔案 盤點清冊及個人資料 作業流程說明。
	4.2 經檢視發現資 料無保存必要時， 是否刪除、銷毀、 停止蒐集、處理、 利用或為其他適當 之處置？	☐ 符合 ☐ 不符合 ☐ 不適用		請說明定期檢視有無 非屬特定目的必要範 圍內之個資、特定目 的消失或期間屆滿而 無保存必要個資之頻 率及相關作業流程。

5.個人資料之風險評估及管理機制 (個人資料保護法施行細則第12條第2項第3款)	5.1 是否定期評估個人資料作業流程之風險，並訂定適當之管控及因應措施？	☐ 符合 ☐ 不符合 ☐ 不適用		請提出風險評估及管理機制之相關佐證資料，例如：風險評估報告、風險處理計畫等。
6.個人資料蒐集、處理、利用作業 (個人資料保護法施行細則第12條第2項第5款； 醫院個人資料檔案安全維護計畫實施辦法第8條、第9條、第10條； 電子病歷製作及管理辦法第6條、第7條、第8條、第9條)	6.1 個人資料蒐集、處理是否具備特定目的並具有法定要件？	☐ 符合 ☐ 不符合 ☐ 不適用		1. 請提出合法蒐集、處理個資之佐證資料，例如：最新個資盤點資料，皆已識別個資蒐集、處理之法定要件。 2. 個資蒐集、處理之法定要件請參考：個人資料保護法第15條（公立醫院）、第19條（私立醫院、醫療法人醫院及其他法人附設醫院）。
	6.2 個人資料之利用，是否符合特定目的之範圍？	☐ 符合 ☐ 不符合 ☐ 不適用		請提出合法利用個資之佐證資料，例如：最新個資盤點資料，皆已識別個資的利用為符合特定目的範圍。
	6.3 目的外利用是否符合法定要件？	☐ 符合 ☐ 不符合 ☐ 不適用		1. 如有目的外利用，請提出其符合之法定要件之佐證資料。 2. 如無目的外利用，可勾選不適用。 3. 個資目的外利用之法定要件請參考：個人資料保護法第16條（公立醫院）、第20條（私立醫院、醫療法人醫院及其他法人附設醫

			院)。
6.4 是否履行告知義務？若未履行告知義務，是否符合免告知之情形？	☐ 符合 ☐ 不符合 ☐ 不適用		1. 請提出告知同意書或相關佐證，並說明免告知之法規依據。 2. 應告知事項及免告知之情形，請參考個人資料保護法第8條、第9條。
6.5 委託他人蒐集、處理或利用個人資料時，是否於委託契約或相關文件明確約定適當之監督事項及方式，並定期確認及記錄確認受託者執行狀況？	☐ 符合 ☐ 不符合 ☐ 不適用		1. 請提出個資委外之廠商清單、合約文件，以及對委外廠商之查核紀錄、缺失追蹤情形等等佐證資料。 2. 委託建置、管理電子病歷資訊系統者，亦應檢附： (1) 受託機構通過中央主管機關認可之資訊安全標準驗證之證明文件； (2) 依電子病歷製作及管理辦法第9條報直轄市、縣(市)主管機關備查之紀錄。
6.6 進行個人資料國際傳輸前，是否檢視及遵循衛生福利部限制國際傳輸之命令或處分？	☐ 符合 ☐ 不符合 ☐ 不適用		1. 請提出進行檢視之說明，如無國際傳輸，可勾選不適用。 2. 電子病歷運用雲端服務或委託受託機構提供雲端服務者，請說明雲端服務之資料儲存地點，如為我國境外者，請提出經中央主管

				機關核准之證明文件。
7. 資料安全管理及人員管理 (個人資料保護法施行細則第12條第2項第6款； 醫院個人資料檔案安全維護計畫實施辦法第8條、第11條； 電子病歷製作及管理辦法第3條)	7.1 是否依業務作業需要，規範個人資料蒐集、處理、利用及其他相關流程之負責人員，設定所屬人員接觸個人資料之權限，並定期檢視其必要性？	☐ 符合 ☐ 不符合 ☐ 不適用		1. 請提出權限設定規範、權限申請及審查紀錄。 2. 實施電子病歷者，請提出權限控管機制（含電子病歷製作、存取、增刪、查閱、複製、傳輸及其他使用權限之管控）及近五年紀錄。
	7.2 是否與所屬人員約定保密義務？	☐ 符合 ☐ 不符合 ☐ 不適用		請提出與所屬人員約定保密之佐證資料，例如：保密切結書、個資保密條款等。
	7.3 人員離職時，是否取消其原在職之存取權限，並要求離職人員將執行業務所持有之文件、資料辦理交接，不得攜離使用？	☐ 符合 ☐ 不符合 ☐ 不適用		請提出離職人員權限異動及文件資料返還之佐證，例如：離職確認單、交接清單等。
	7.4 傳輸個人資料時，是否依不同傳輸方式，採取適當之安全措施？	☐ 符合 ☐ 不符合 ☐ 不適用		1. 請提出對外傳送個資檔案之相關規範，以及執行安全措施之佐證，例如：資通訊系統網際網路傳輸個人資料之安全加密機制。 2. 實施電子病歷者，請提出傳輸加密機制及近五年紀錄；國際傳輸電子病歷者，應提出符合國際標準組織通用加

				密機制之證明。
8. 認知宣導及教育訓練 (個人資料保護法施行細則第12條第2項第7款、醫院個人資料檔案安全維護計畫實施辦法第12條)	8.1 是否定期對實施所屬人員之個人資料保護與管理認知宣導及教育訓練，使所屬人員明瞭個人資料保護相關法令規定、責任範圍、作業程序及應遵守之相關措施？	☐ 符合 ☐ 不符合 ☐ 不適用		請提出對所屬人員辦理教育訓練之佐證，例如：訓練教材、出席紀錄及課後評量結果等。
9. 設備安全管理措施 (個人資料保護法施行細則第12條第2項第8款；醫院個人資料檔案安全維護計畫實施辦法第13條、第13-1條；電子病歷製作及管理辦法第3條、第4條、第15條)	9.1 是否依據作業內容及環境之不同，訂定各類設備或儲存媒體之使用規範，並據以落實？	☐ 符合 ☐ 不符合 ☐ 不適用		1. 請提出各類設備或儲存媒體之使用規範，以及落實之佐證，例如：進出入登記簿、系統主機、防火牆、個人電腦等設備之定期檢查及維護紀錄。 2. 實施電子病歷者，請提出標準作業機制（包括：系統建置、維護及稽核之標準作業程序）及近五年紀錄。
	9.2 有無制定資料銷毀程序，並依規定銷毀資料？	☐ 符合 ☐ 不符合 ☐ 不適用		1. 請提出資料銷毀程序，包括電腦、自動化機器或其他儲存媒介物於報廢、汰換或轉作其他用途時，確保所含個人資料完全移除或清除之程序。 2. 請提出落實銷毀程序之紀錄，例如資料銷毀紀錄表冊。

9.3 個人資料有加密之必要者，於蒐集、處理或利用時，是否採取適當之加密措施或配置安全防護系統？	☐ 符合 ☐ 不符合 ☐ 不適用		請說明資料加密措施或其他安全防護措施，例如對資料庫加密、個資檔案設置開啟密碼。
9.4 個人資料有備份之必要者，是否對備份資料採取適當之保護措施？	☐ 符合 ☐ 不符合 ☐ 不適用		1. 請提出資料備份機制相關規範制度文件。 2. 實施電子病歷者，請提出系統安全機制（包括：確保系統安全、時間正確、系統備援與資料備份及其他保護措施）及近五年紀錄。
9.5 蒐集、處理或利用個人資料之資訊通訊系統，是否採行使用者身分確認及保護機制？	☐ 符合 ☐ 不符合 ☐ 不適用		1. 請說明使用者身分認證機制，並提出相關佐證，例如：帳號權限清查紀錄單。 2. 實施電子病歷者，請提出使用者身分確認機制及近五年紀錄。 3. 若無使用資通訊系統者，請勾選「不適用」。
9.6 蒐集、處理或利用個人資料之資訊通訊系統，是否採行個人資料顯示之隱碼機制？	☐ 符合 ☐ 不符合 ☐ 不適用		1. 請說明個人資料顯示之隱碼機制，並提出相關佐證紀錄，例如：提供系統畫面截圖。 2. 實施電子病歷者，請提出個資隱碼或其他適當保護措施之機制及近五年紀錄。 3. 若無使用資通訊

			系統者，請勾選「不適用」。
9.7 蒐集、處理或利用個人資料之資訊系統，是否採行個人資料檔案及資料庫之存取控制與保護監控措施？	☐ 符合 ☐ 不符合 ☐ 不適用		1. 請說明個人資料檔案及資料庫之存取控制與保護監控措施，例如：存取日誌留存、分析及告警機制。 2. 實施電子病歷者，請提出系統使用及資料存取監控措施說明，及近五年紀錄。 3. 若無使用資通訊系統者，請勾選「不適用」。
9.8 蒐集、處理或利用個人資料之資訊系統，是否採行防止外部網路入侵對策？	☐ 符合 ☐ 不符合 ☐ 不適用		1. 請說明防止外部網路入侵對策，例如：設置防火牆、設置入侵偵測和防禦系統（IDS/IPS）等。 2. 實施電子病歷者，請提出防範網路入侵之機制及近五年紀錄。 3. 若無使用資通訊系統者，請勾選「不適用」。
9.9 蒐集、處理或利用個人資料之資訊系統，是否採行非法或異常使用行為之監控與因應機制？	☐ 符合 ☐ 不符合 ☐ 不適用		1. 請提出非法或異常使用行為之監控與因應機制。 2. 實施電子病歷者，請提出非法或異常使用之因應措施之機制及近五年紀錄。 3. 若無使用資通訊系統者，請勾選「不適用」。
9.10 電子病歷系統	☐ 符合		1. 請提出系統開發、上線、維護

	有無訂定系統開發、上線、維護及應用軟體之驗證確認程序，並據以落實？	☐ 不符合 ☐ 不適用		及應用軟體之驗證確認程序及近五年執行紀錄。 2. 若無實施電子病歷者，請勾選「不適用」。
	9.11 電子病歷運用雲端服務或委託受託機構提供雲端服務者，是否確認雲端服務者通過資訊安全標準驗證，且採取風險控管措施、避免醫療業務中斷措施、停止或終止服務時資料移轉返還機制？	☐ 符合 ☐ 不符合 ☐ 不適用		1. 請提出雲端服務者通過中央主管機關認可之資訊安全標準驗證之證明文件。 2. 請提出雲端服務之風險管控措施、避免醫療業務中斷措施、監督措施及停止或終止雲端服務時資料移轉機制，及其相關紀錄。 3. 實施電子病歷，但無運用雲端服務或委託受託機構提供雲端服務者，請勾選不適用。
	9.12 蒐集、處理或利用個人資料之資訊通訊系統之防止外部網路入侵對策及非法或異常使用行為之監控與因應機制，是否定期演練及檢討改善？	☐ 符合 ☐ 不符合 ☐ 不適用		1. 請提出防止外部網路入侵對策及非法或異常使用行為之監控與因應機制進行演練或檢討，例如針對系統進行演練作業或對防火牆政策進行檢討等。 2. 若無使用資通訊系統者，請勾選「不適用」。
10. 資料安全稽核機制 (個人資料保護法施行細則第12條第2項第9款；	10.1 是否指定資料安全評核之查核人員，定期評核安全維護計畫之執行情	☐ 符合 ☐ 不符合 ☐ 不適用		1. 請提出資料安全稽核機制之作法，且應包含稽核之頻率及執行方式，並請提出

醫院個人資料檔案安全維護計畫實施辦法第18條； 電子病歷製作及管理辦法第3條)	形及成效，並將評核結果，向醫院提出報告？			評核報告。 2. 總床數一百床以上者，應每年評核，且查核人員與安全維護計畫之專責人員不得為同一人。
	10.2 依前項評核結果發現計畫不符合令或不符合法令之虞者，是否立即改善？	☐ 符合 ☐ 不符合 ☐ 不適用		請提出持續改善之作法，例如矯正單/追蹤紀錄等檢視或修正之紀錄。
11. 使用紀錄、軌跡資料及證據保存 (個人資料保護法施行細則第12條第2項第10款； 醫院個人資料檔案安全維護計畫實施辦法第15條； 電子病歷製作及管理辦法第13條、第14條、第16條、第17條)	11.1 是否留存個人資料使用紀錄、軌跡資料及其他證據資料？	☐ 符合 ☐ 不符合 ☐ 不適用		1. 請提供個人資料使用紀錄、自動化機器設備之軌跡資料及其他相關之證據資料之保存紀錄。 2. 總床數一百床以上者，紀錄應留存至少六個月。
	11.2 實施電子病歷者，有無於病歷保存期間內，保存電子病歷之完整紀錄？	☐ 符合 ☐ 不符合 ☐ 不適用		1. 請提出醫療法第70條第1項所定病歷保存期間內，電子病歷存取、增刪、查閱、複製與其他相關事項，及其執行人員、時間與內容之完整紀錄。 2. 電子病歷移轉由承接者保存者，請提出近五年內移轉紀錄。 3. 銷毀電子病歷或原件者，請提出近五年內之銷毀紀錄。
12. 個人資料安全維護之整體持續改善 (個人資料保護法施行細則第12條第2項第11	12.1 是否每年參酌安全維護計畫執行狀況、技術發展、	☐ 符合 ☐ 不符合 ☐ 不適用		1. 請提出個人資料管理或安全維護辦法以及完整之版本資訊(安全

款； 醫院個人資料檔案安全 維護計畫實施辦法第17 條)	法令修正或其他因 素，檢視所定安全 維護計畫之合宜 性，必要時並予以 修正？			維護計畫)，包含 但不限於日期、 提報人及核定人 等相關資訊。 2. 總床數未達一百 床者，得勾選不 適用。
13. 業務終止後個人 資料處理方法 (醫院個人資料檔案安 全維護計畫實施辦法第 16條)	13.1 是否訂定業務 終止後，銷毀、移 轉、刪除、停止處 理或利用個人資料 之措施？	☐ 符合 ☐ 不符合 ☐ 不適用		請提出業務終止後， 規範個人資料處理方 法之程序文件。
	13.2 業務終止後， 是否對個人資料處 理方法之措施製作 紀錄，並保存至少 5年？	☐ 符合 ☐ 不符合 ☐ 不適用		1. 請提出業務終止 後，個人資料處 理方法紀錄之留 存情形。 2. 如無業務終止 者，請勾選不適 用。
受檢醫院簽章：				

填表說明：

一、檢查結果欄：依檢查實際狀況，參考相關佐證資料填具查核結果。

(一) 符合：實際作業已依檢查內容訂定相關規範，並已有相關實作紀錄，或已建立標準規範而尚未有實際作業。

(二) 不符合：未完全依檢查內容要求訂定相關程序，或未完全依相關程序執行並產生實作紀錄；並請於說明欄儘可能詳述未符合之情形與樣態。

(三) 不適用：實際作業排除檢查內容之適用。

二、說明欄位：應記錄檢查之參考佐證資料或簡述實際作業狀況。

三、法源依據：

(一) 個人資料保護法、個人資料保護法施行細則。

(二) 醫院個人資料檔案安全維護計畫實施辦法。

(三) 醫療機構電子病歷製作及管理辦法。

附錄一：相關法令

一、個人資料保護法

第一章 總則

第1條

為規範個人資料之蒐集、處理及利用，以避免人格權受侵害，並促進個人資料之合理利用，特制定本法。

第1-1條

本法之主管機關為個人資料保護委員會。

第1-2條

中央及地方各級政府應致力配合推動達成本法立法目的之具體措施，確保其所轄公務機關及所管非公務機關，於執行職務及業務時遵守本法規定，共同建構安全可信賴之個人資料保護環境。

為落實個人資料保護相關事項，主管機關得召開個人資料保護政策推進會議；其運作方式及其他相關事項之辦法，由主管機關定之。

第2條

本法用詞，定義如下：

- 一、個人資料：指自然人之姓名、出生年月日、國民身分證統一編號、護照號碼、特徵、指紋、婚姻、家庭、教育、職業、病歷、醫療、基因、性生活、健康檢查、犯罪前科、聯絡方式、財務情況、社會活動及其他得以直接或間接方式識別該個人之資料。
- 二、個人資料檔案：指依系統建立而得以自動化機器或其他非自動化方式檢索、整理之個人資料之集合。
- 三、蒐集：指以任何方式取得個人資料。
- 四、處理：指為建立或利用個人資料檔案所為資料之記錄、輸入、儲存、編輯、更正、複製、檢索、刪除、輸出、連結或內部傳送。
- 五、利用：指將蒐集之個人資料為處理以外之使用。
- 六、國際傳輸：指將個人資料作跨國（境）之處理或利用。
- 七、公務機關：指依法行使公權力之中央或地方機關或行政法人。
- 八、非公務機關：指前款以外之自然人、法人或其他團體。
- 九、當事人：指個人資料之本人。

第3條

當事人就其個人資料依本法規定行使之下列權利，不得預先拋棄或以特約限制之：

- 一、查詢或請求閱覽。
- 二、請求製給複製本。
- 三、請求補充或更正。

四、請求停止蒐集、處理或利用。

五、請求刪除。

第4條

受公務機關或非公務機關委託蒐集、處理或利用個人資料者，於本法適用範圍內，視同委託機關。

第5條

個人資料之蒐集、處理或利用，應尊重當事人之權益，依誠實及信用方法為之，不得逾越特定目的之必要範圍，並應與蒐集之目的具有正當合理之關聯。

第6條

有關病歷、醫療、基因、性生活、健康檢查及犯罪前科之個人資料，不得蒐集、處理或利用。但有下列情形之一者，不在此限：

一、法律明文規定。

二、公務機關執行法定職務或非公務機關履行法定義務必要範圍內，且事前或事後有適當安全維護措施。

三、當事人自行公開或其他已合法公開之個人資料。

四、公務機關或學術研究機構基於醫療、衛生或犯罪預防之目的，為統計或學術研究而有必要，且資料經過提供者處理後或經蒐集者依其揭露方式無從識別特定之當事人。

五、為協助公務機關執行法定職務或非公務機關履行法定義務必要範圍內，且事前或事後有適當安全維護措施。

六、經當事人書面同意。但逾越特定目的之必要範圍或其他法律另有限制不得僅依當事人書面同意蒐集、處理或利用，或其同意違反其意願者，不在此限。

依前項規定蒐集、處理或利用個人資料，準用第八條、第九條規定；其中前項第六款之書面同意，準用第七條第一項、第二項及第四項規定，並以書面為之。

第7條

第十五條第二款及第十九條第一項第五款所稱同意，指當事人經蒐集者告知本法所定應告知事項後，所為允許之意思表示。

第十六條第七款、第二十條第一項第六款所稱同意，指當事人經蒐集者明確告知特定目的外之其他利用目的、範圍及同意與否對其權益之影響後，單獨所為之意思表示。

公務機關或非公務機關明確告知當事人第八條第一項各款應告知事項時，當事人如未表示拒絕，並已提供其個人資料者，推定當事人已依第十五條第二款、第十九條第一項第五款之規定表示同意。

蒐集者就本法所稱經當事人同意之事實，應負舉證責任。

第8條

公務機關或非公務機關依第十五條或第十九條規定向當事人蒐集個人資料時，應明確告知當事人下列事項：

- 一、公務機關或非公務機關名稱。
 - 二、蒐集之目的。
 - 三、個人資料之類別。
 - 四、個人資料利用之期間、地區、對象及方式。
 - 五、當事人依第三條規定得行使之權利及方式。
 - 六、當事人得自由選擇提供個人資料時，不提供將對其權益之影響。
- 有下列情形之一者，得免為前項之告知：

- 一、依法律規定得免告知。
- 二、個人資料之蒐集係公務機關執行法定職務或非公務機關履行法定義務所必要。
- 三、告知將妨害公務機關執行法定職務。
- 四、告知將妨害公共利益。
- 五、當事人明知應告知之內容。
- 六、個人資料之蒐集非基於營利之目的，且對當事人顯無不利之影響。

第9條

公務機關或非公務機關依第十五條或第十九條規定蒐集非由當事人提供之個人資料，應於處理或利用前，向當事人告知個人資料來源及前條第一項第一款至第五款所列事項。

有下列情形之一者，得免為前項之告知：

- 一、有前條第二項所列各款情形之一。
 - 二、當事人自行公開或其他已合法公開之個人資料。
 - 三、不能向當事人或其法定代理人為告知。
 - 四、基於公共利益為統計或學術研究之目的而有必要，且該資料須經提供者處理後或蒐集者依其揭露方式，無從識別特定當事人者為限。
 - 五、大眾傳播業者基於新聞報導之公益目的而蒐集個人資料。
- 第一項之告知，得於首次對當事人為利用時併同為之。

第10條

公務機關或非公務機關應依當事人之請求，就其蒐集之個人資料，答覆查詢、提供閱覽或製給複製本。但有下列情形之一者，不在此限：

- 一、妨害國家安全、外交及軍事機密、整體經濟利益或其他國家重大利益。
- 二、妨害公務機關執行法定職務。
- 三、妨害該蒐集機關或第三人之重大利益。

第11條

公務機關或非公務機關應維護個人資料之正確，並應主動或依當事人之請求更正或補充之。

個人資料正確性有爭議者，應主動或依當事人之請求停止處理或利用。但因執行職務或業務所必須，或經當事人書面同意，並經註明其爭議者，不在此限。

個人資料蒐集之特定目的消失或期限屆滿時，應主動或依當事人之請求，刪除、停

止處理或利用該個人資料。但因執行職務或業務所必須或經當事人書面同意者，不在此限。

違反本法規定蒐集、處理或利用個人資料者，應主動或依當事人之請求，刪除、停止蒐集、處理或利用該個人資料。

因可歸責於公務機關或非公務機關之事由，未為更正或補充之個人資料，應於更正或補充後，通知曾提供利用之對象。

第 12 條

公務機關或非公務機關知悉所保有之個人資料被竊取、竄改、毀損、滅失或洩漏時，應通知當事人。

前項情形符合一定通報範圍者，公務機關或非公務機關應通報下列機關：

- 一、公務機關：向主管機關及依第二十一條之一第一項規定收受其實施情形之機關通報。
- 二、非公務機關：向主管機關通報。主管機關受理通報後，並轉知其目的事業主管機關。

第一項情形，公務機關或非公務機關應採取即時有效之應變措施，防止事故之擴大，及記載相關事實、影響、已採取之因應措施，並保存相關紀錄，以備主管機關查驗。前三項應通知或通報之內容、方式、時限與通報範圍、應變措施、紀錄保存及其他相關事項之辦法，由主管機關定之。

第 13 條

公務機關或非公務機關受理當事人依第十條規定之請求，應於十五日內，為准駁之決定；必要時，得予延長，延長之期間不得逾十五日，並應將其原因以書面通知請求人。

公務機關或非公務機關受理當事人依第十一條規定之請求，應於三十日內，為准駁之決定；必要時，得予延長，延長之期間不得逾三十日，並應將其原因以書面通知請求人。

第 14 條

查詢或請求閱覽個人資料或製給複製本者，公務機關或非公務機關得酌收必要成本費用。

第二章 公務機關對個人資料之蒐集、處理及利用

第 15 條

公務機關對個人資料之蒐集或處理，除第六條第一項所規定資料外，應有特定目的，並符合下列情形之一者：

- 一、執行法定職務必要範圍內。
- 二、經當事人同意。
- 三、對當事人權益無侵害。

第 16 條

公務機關對個人資料之利用，除第六條第一項所規定資料外，應於執行法定職務必

要範圍內為之，並與蒐集之特定目的相符。但有下列情形之一者，得為特定目的外之利用：

- 一、法律明文規定。
- 二、為維護國家安全或增進公共利益所必要。
- 三、為免除當事人之生命、身體、自由或財產上之危險。
- 四、為防止他人權益之重大危害。
- 五、公務機關或學術研究機構基於公共利益為統計或學術研究而有必要，且資料經過提供者處理後或經蒐集者依其揭露方式無從識別特定之當事人。
- 六、有利於當事人權益。
- 七、經當事人同意。

第 17 條

公務機關應將下列事項公開於電腦網站，或以其他適當方式供公眾查閱；其有變更者，亦同：

- 一、個人資料檔案名稱。
- 二、保有機關名稱及聯絡方式。
- 三、個人資料檔案保有之依據及特定目的。
- 四、個人資料之類別。

第 18 條

公務機關應置個人資料保護長，由機關首長指派適當人員兼任，並配置適當人力及資源，負責統籌推動及督導考核本機關、所屬或所監督公務機關之個人資料保護相關事務。

公務機關應指定專人辦理個人資料檔案安全維護事項，防止個人資料被竊取、竄改、毀損、滅失或洩漏；其安全維護、管理機制、應採取之措施及其他相關事項之辦法，由主管機關定之。

公務機關不得因所屬人員依法執行個人資料保護職務而予以不利之處分或管理措施。主管機關應妥善規劃推動第一項及第二項相關人員之職能訓練，增進其個人資料保護專業知能。

第一項、第二項相關人員之職掌、職能條件、訓練及其他相關事項之辦法，由主管機關定之。

第三章 非公務機關對個人資料之蒐集、處理及利用

第 19 條

非公務機關對個人資料之蒐集或處理，除第六條第一項所規定資料外，應有特定目的，並符合下列情形之一者：

- 一、法律明文規定。
- 二、與當事人有契約或類似契約之關係，且已採取適當之安全措施。
- 三、當事人自行公開或其他已合法公開之個人資料。
- 四、學術研究機構基於公共利益為統計或學術研究而有必要，且資料經過提供者處

理後或經蒐集者依其揭露方式無從識別特定之當事人。

五、經當事人同意。

六、為增進公共利益所必要。

七、個人資料取自於一般可得之來源。但當事人對該資料之禁止處理或利用，顯有更值得保護之重大利益者，不在此限。

八、對當事人權益無侵害。

蒐集或處理者知悉或經當事人通知依前項第七款但書規定禁止對該資料之處理或利用時，應主動或依當事人之請求，刪除、停止處理或利用該個人資料。

第 20 條

非公務機關對個人資料之利用，除第六條第一項所規定資料外，應於蒐集之特定目的必要範圍內為之。但有下列情形之一者，得為特定目的外之利用：

一、法律明文規定。

二、為增進公共利益所必要。

三、為免除當事人之生命、身體、自由或財產上之危險。

四、為防止他人權益之重大危害。

五、公務機關或學術研究機構基於公共利益為統計或學術研究而有必要，且資料經過提供者處理後或經蒐集者依其揭露方式無從識別特定之當事人。

六、經當事人同意。

七、有利於當事人權益。

非公務機關依前項規定利用個人資料行銷者，當事人表示拒絕接受行銷時，應即停止利用其個人資料行銷。

非公務機關於首次行銷時，應提供當事人表示拒絕接受行銷之方式，並支付所需費用。

第 20-1 條

非公務機關保有個人資料檔案者，應辦理安全維護事項，防止個人資料被竊取、竄改、毀損、滅失或洩漏。

前項個人資料檔案安全維護事項、管理機制、應採取之措施及其他相關事項之辦法，由主管機關定之。

第 21 條

非公務機關為國際傳輸個人資料，而有下列情形之一者，主管機關得限制之：

一、涉及國家重大利益。

二、國際條約或協定有特別規定。

三、接受國對於個人資料之保護未有完善之法規，致有損當事人權益之虞。

四、以迂迴方法向第三國（地區）傳輸個人資料規避本法。

第三章之一 行政監督

第一節 對公務機關之監督

第 21-1 條

公務機關應每年向上級機關或監督機關提出個人資料保護管理事項實施情形；無上級機關或監督機關者，依下列各款規定辦理：

- 一、總統府、國家安全會議及五院，向主管機關提出。
- 二、直轄市政府、直轄市議會、縣（市）政府及縣（市）議會，向主管機關提出。
- 三、直轄市山地原住民區公所、直轄市山地原住民區民代表會，向直轄市政府提出；鄉（鎮、市）公所、鄉（鎮、市）民代表會，向縣政府提出。

公務機關應督導及稽核其所屬、所監督之公務機關、所轄鄉（鎮、市）公所、直轄市山地原住民區公所及鄉（鎮、市）民代表會、直轄市山地原住民區民代表會之個人資料保護管理事項實施情形。

依前項規定稽核後，發現受稽核機關實施情形有缺失或待改善者，受稽核機關應向稽核機關提出改善報告，並由稽核機關審查後，連同稽核結果送交主管機關。

稽核機關或主管機關認有必要時，得要求受稽核機關進行說明或調整。

前四項實施情形之必要內容、稽核之頻率、內容與方法、結果之交付、改善報告之提出及其他相關事項之辦法，由主管機關定之。

第 21-2 條

主管機關應定期或不定期稽核公務機關之個人資料保護管理事項實施情形；必要時，得請求前條第二項所定稽核機關協助。

依前項規定稽核後，發現受稽核機關實施情形有缺失或待改善者，受稽核機關應提出改善報告，送交依前條第一項規定收受其實施情形之機關審查後，由該審查機關送交主管機關。

前項審查機關或主管機關認有必要時，得要求受稽核機關進行說明或調整。

前三項稽核之頻率、內容與方法、改善報告之提出及其他相關事項之辦法，由主管機關定之。

依前條及本條參與稽核之人員，對於因執行稽核所知悉或持有之資料，負保密義務。

第 21-3 條

公務機關有違反本法規定之虞時，主管機關得請公務機關提出資料及說明，或派員攜帶執行職務證明文件進行實地檢查，除依法規規定有保密之必要者外，公務機關及其相關人員有配合之義務。

前項實地檢查，必要時得請求第二十一條之一第二項所定稽核機關協助。

參與檢查之人員，對於因執行檢查所知悉或持有之資料，負保密義務。

第 21-4 條

公務機關有違反本法規定之情事者，由主管機關令其限期改正，該公務機關應依限為適當之改正，並應將改正情形以書面答覆主管機關。

公務機關未依前項規定改正者，主管機關得公布其名稱及其違法情形。

公務機關所屬人員未依本法規定辦理者，應按其情節輕重，依相關法令規定予以懲戒、懲處或懲罰。

第 21-5 條

本節之規定，於情報機關不適用之。

第二節 對非公務機關之監督

第22條

主管機關認非公務機關有違反本法規定之虞，或為檢視其落實本法情形而認有必要時，得依下列方式進行檢查：

- 一、通知非公務機關或其相關人員陳述意見。
- 二、通知非公務機關或其相關人員提供必要之文書、資料、物品或為其他配合措施。
- 三、自行或會同中央目的事業主管機關、直轄市、縣（市）政府或其他有關機關派員攜帶執行職務證明文件進入檢查，並得令相關人員為必要之說明、配合措施或提供相關證明資料。

前項檢視落實本法情形檢查作業之規劃、評估方式、考量因素、中央目的事業主管機關、直轄市、縣（市）政府或有關機關之協力事項及其他相關事項之辦法，由主管機關定之。

主管機關為第一項檢查時，對於得沒入或可為證據之個人資料或其檔案，得扣留或複製之。對於應扣留或複製之物，得要求其所有人、持有人或保管人提出或交付；無正當理由拒絕提出、交付或抗拒扣留或複製者，得採取對該非公務機關權益損害最少之方法強制為之。

對於依第一項或前項所為之通知、進入、檢查或處分，非公務機關及其相關人員無正當理由不得規避、妨礙或拒絕。

主管機關為第一項第三款檢查時，得率同資訊、電信、法律或其他專業人員共同為之。

參與檢查之人員，對於因執行檢查所知悉或持有之資料，負保密義務，並應注意被檢查者之名譽。

第一項檢查之執行，主管機關於必要時得請求中央目的事業主管機關、直轄市、縣（市）政府或其他相關機關（構）配合採取有效措施或提供協助。

第23條

對於前條第三項扣留物或複製物，應加封緘或其他標識，並為適當之處置；其不便搬運或保管者，得命人看守或交由所有人或其他適當之人保管。

扣留物或複製物已無留存之必要，或決定不予處罰或未為沒入之裁處者，應發還之。但應沒入或為調查他案應留存者，不在此限。

第24條

非公務機關、物之所有人、持有人、保管人或利害關係人對前二條之要求、強制、扣留或複製行為不服者，得向主管機關聲明異議。

前項聲明異議，主管機關認為有理由者，應立即停止或變更其行為；認為無理由者，得繼續執行。經該聲明異議之人請求時，應將聲明異議之理由製作紀錄交付之。

對於主管機關前項決定不服者，僅得於對該案件之實體決定聲明不服時一併聲明之。但第一項之人依法不得對該案件之實體決定聲明不服時，得單獨對第一項之行為逕

行提起行政訴訟。

第 25 條

非公務機關有違反本法規定之情事者，主管機關除依本法規定裁處罰鍰外，並得為下列處分：

- 一、禁止蒐集、處理或利用個人資料。
- 二、命令刪除經處理之個人資料檔案。
- 三、沒入或令銷毀違法蒐集之個人資料。
- 四、公布違法情形，及其姓名或名稱與負責人。

主管機關為前項處分時，應於防制違反本法規定情事之必要範圍內，採取對該非公務機關權益損害最少之方法為之。

第 26 條

主管機關依第二十二條規定檢查後，未發現有違反本法規定之情事者，經該非公務機關同意後，得公布檢查結果。

第 27 條

（刪除）

第四章 損害賠償及團體訴訟

第 28 條

公務機關違反本法規定，致個人資料遭不法蒐集、處理、利用或其他侵害當事人權利者，負損害賠償責任。但損害因天災、事變或其他不可抗力所致者，不在此限。被害人雖非財產上之損害，亦得請求賠償相當之金額；其名譽被侵害者，並得請求為回復名譽之適當處分。

依前二項情形，如被害人不易或不能證明其實際損害額時，得請求法院依侵害情節，以每人每一事件新臺幣五百元以上二萬元以下計算。

對於同一原因事實造成多數當事人權利受侵害之事件，經當事人請求損害賠償者，其合計最高總額以新臺幣二億元為限。但因該原因事實所涉利益超過新臺幣二億元者，以該所涉利益為限。

同一原因事實造成之損害總額逾前項金額時，被害人所受賠償金額，不受第三項所定每人每一事件最低賠償金額新臺幣五百元之限制。

第二項請求權，不得讓與或繼承。但以金額賠償之請求權已依契約承諾或已起訴者，不在此限。

第 29 條

非公務機關違反本法規定，致個人資料遭不法蒐集、處理、利用或其他侵害當事人權利者，負損害賠償責任。但能證明其無故意或過失者，不在此限。

依前項規定請求賠償者，適用前條第二項至第六項規定。

第 30 條

損害賠償請求權，自請求權人知有損害及賠償義務人時起，因二年間不行使而消滅；自損害發生時起，逾五年者，亦同。

第 31 條

損害賠償，除依本法規定外，公務機關適用國家賠償法之規定，非公務機關適用民法之規定。

第 32 條

依本章規定提起訴訟之財團法人或公益社團法人，應符合下列要件：

- 一、財團法人之登記財產總額達新臺幣一千萬元或社團法人之社員人數達一百人。
- 二、保護個人資料事項於其章程所定目的範圍內。
- 三、許可設立三年以上。

第 33 條

依本法規定對於公務機關提起損害賠償訴訟者，專屬該機關所在地之地方法院管轄。對於非公務機關提起者，專屬其主事務所、主營業所或住所地之地方法院管轄。

前項非公務機關為自然人，而其在中華民國現無住所或住所不明者，以其在中華民國之居所，視為其住所；無居所或居所不明者，以其在中華民國最後之住所，視為其住所；無最後住所者，專屬中央政府所在地之地方法院管轄。

第一項非公務機關為自然人以外之法人或其他團體，而其在中華民國現無主事務所、主營業所或主事務所、主營業所不明者，專屬中央政府所在地之地方法院管轄。

第 34 條

對於同一原因事實造成多數當事人權利受侵害之事件，財團法人或公益社團法人經受有損害之當事人二十人以上以書面授與訴訟實施權者，得以自己之名義，提起損害賠償訴訟。當事人得於言詞辯論終結前以書面撤回訴訟實施權之授與，並通知法院。

前項訴訟，法院得依聲請或依職權公告曉示其他因同一原因事實受有損害之當事人，得於一定期間內向前項起訴之財團法人或公益社團法人授與訴訟實施權，由該財團法人或公益社團法人於第一審言詞辯論終結前，擴張應受判決事項之聲明。

其他因同一原因事實受有損害之當事人未依前項規定授與訴訟實施權者，亦得於法院公告曉示之一定期間內起訴，由法院併案審理。

其他因同一原因事實受有損害之當事人，亦得聲請法院為前項之公告。

前二項公告，應揭示於法院公告處、資訊網路及其他適當處所；法院認為必要時，並得命登載於公報或新聞紙，或用其他方法公告之，其費用由國庫墊付。

依第一項規定提起訴訟之財團法人或公益社團法人，其標的價額超過新臺幣六十萬元者，超過部分暫免徵裁判費。

第 35 條

當事人依前條第一項規定撤回訴訟實施權之授與者，該部分訴訟程序當然停止，該當事人應即聲明承受訴訟，法院亦得依職權命該當事人承受訴訟。

財團法人或公益社團法人依前條規定起訴後，因部分當事人撤回訴訟實施權之授與，致其餘部分不足二十人者，仍得就其餘部分繼續進行訴訟。

第 36 條

各當事人於第三十四條第一項及第二項之損害賠償請求權，其時效應分別計算。

第 37 條

財團法人或公益社團法人就當事人授與訴訟實施權之事件，有為一切訴訟行為之權。但當事人得限制其為捨棄、撤回或和解。

前項當事人中一人所為之限制，其效力不及於其他當事人。

第一項之限制，應於第三十四條第一項之文書內表明，或以書狀提出於法院。

第 38 條

當事人對於第三十四條訴訟之判決不服者，得於財團法人或公益社團法人上訴期間屆滿前，撤回訴訟實施權之授與，依法提起上訴。

財團法人或公益社團法人於收受判決書正本後，應即將其結果通知當事人，並應於七日內將是否提起上訴之意旨以書面通知當事人。

第 39 條

財團法人或公益社團法人應將第三十四條訴訟結果所得之賠償，扣除訴訟必要費用後，分別交付授與訴訟實施權之當事人。

提起第三十四條第一項訴訟之財團法人或公益社團法人，均不得請求報酬。

第 40 條

依本章規定提起訴訟之財團法人或公益社團法人，應委任律師代理訴訟。

第五章 罰則

第 41 條

意圖為自己或第三人不法之利益或損害他人之利益，而違反第六條第一項、第十五條、第十六條、第十九條、第二十條第一項規定，或依第二十一條限制國際傳輸之命令或處分，足生損害於他人者，處五年以下有期徒刑，得併科新臺幣一百萬元以下罰金。

第 42 條

意圖為自己或第三人不法之利益或損害他人之利益，而對於個人資料檔案為非法變更、刪除或以其他非法方法，致妨害個人資料檔案之正確而足生損害於他人者，處五年以下有期徒刑、拘役或科或併科新臺幣一百萬元以下罰金。

第 43 條

中華民國人民在中華民國領域外對中華民國人民犯前二條之罪者，亦適用之。

第 44 條

公務員假借職務上之權力、機會或方法，犯本章之罪者，加重其刑至二分之一。

第 45 條

本章之罪，須告訴乃論。但犯第四十一條之罪者，或對公務機關犯第四十二條之罪者，不在此限。

第 46 條

犯本章之罪，其他法律有較重處罰規定者，從其規定。

第 47 條

非公務機關有下列情事之一者，由主管機關處新臺幣五萬元以上五十萬元以下罰鍰，並令限期改正，屆期未改正者，按次處罰之：

- 一、違反第六條第一項規定。
- 二、違反第十九條規定。
- 三、違反第二十條第一項規定。
- 四、違反依第二十一條規定所為限制國際傳輸之命令或處分。

第 48 條

非公務機關有下列情事之一者，由主管機關令其限期改正，屆期未改正者，按次處新臺幣二萬元以上二十萬元以下罰鍰：

- 一、違反第八條或第九條規定。
- 二、違反第十條、第十一條或第十三條規定。
- 三、違反第十二條第一項或依第四項所定辦法中有關通知之內容、方式或時限之規定。
- 四、違反第二十條第二項或第三項規定。

非公務機關違反第十二條第二項、第三項或依第四項所定辦法中有關通報之內容、方式、時限、應變措施、紀錄保存之規定者，由主管機關處新臺幣二萬元以上二十萬元以下罰鍰，並令其限期改正，屆期未改正者，按次處罰。

非公務機關有下列情事之一者，由主管機關處新臺幣二萬元以上二百萬元以下罰鍰，並令其限期改正，屆期未改正者，按次處新臺幣十五萬元以上一千五百萬元以下罰鍰：

- 一、違反第二十條之一第一項規定。
- 二、違反依第二十條之一第二項所定辦法中有關個人資料檔案安全維護事項、管理機制、應採取措施之規定。
- 三、未依第五十一條之一第三項訂定個人資料檔案安全維護計畫或業務終止後個人資料處理方法。
- 四、違反第五十一條之一第四項所定辦法中有關計畫或處理方法應具備之內容、執行方式或基準之規定。

非公務機關有前項各款情事之一，其情節重大者，由主管機關處新臺幣十五萬元以上一千五百萬元以下罰鍰，並令其限期改正，屆期未改正者，按次處罰。

第 49 條

非公務機關違反第二十二條第四項規定者，由主管機關處新臺幣二萬以上二十萬元以下罰鍰。

第 50 條

非公務機關之代表人、管理人或其他有代表權人，因該非公務機關依前三條規定受罰鍰處罰時，除能證明已盡防止義務者外，應並受同一額度罰鍰之處罰。

第六章 附則

第 51 條

有下列情形之一者，不適用本法規定：

- 一、自然人為單純個人或家庭活動之目的，而蒐集、處理或利用個人資料。
- 二、於公開場所或公開活動中所蒐集、處理或利用之未與其他個人資料結合之影音資料。

公務機關及非公務機關，在中華民國領域外對中華民國人民個人資料蒐集、處理或利用者，亦適用本法。

第 51-1 條

第二十二條第一項、第三項至第七項、第二十三條至第二十六條、第四十七條至第五十條所定對非公務機關之監督管理事項，於主管機關成立之日起六年內，由主管機關報請行政院公告一定範圍之非公務機關，仍由中央目的事業主管機關或直轄市、縣（市）政府管轄。

主管機關應每二年會商相關機關後，報請行政院調整減列前項公告所定一定範圍之非公務機關。

中央目的事業主管機關得指定前二項公告範圍之非公務機關訂定個人資料檔案安全維護計畫或業務終止後個人資料處理方法。

前項計畫、處理方法應具備之內容、執行方式或基準及其他相關事項之辦法，由中央目的事業主管機關比照主管機關依第二十條之一第二項訂定之辦法定之；並得為更嚴格之規定。

第 52 條

第十二條第二項、第二十二條第一項、第三項、第五項、第七項、第二十三條及第二十四條規定由主管機關執行之權限，主管機關得委託或委辦其他機關（構）、行政法人或公益團體辦理。

於前條第一項及第二項公告之範圍內，中央目的事業主管機關或直轄市、縣（市）政府得將第二十二條第一項、第三項、第五項、第七項、第二十三條及第二十四條規定之執行權限，委任所屬機關、委託或委辦其他機關（構）、行政法人或公益團體辦理。

依前二項規定受委託、委辦或委任者，其成員對於因執行相關事務所知悉或持有之資料，負保密義務。

第一項及第二項之公益團體，不得依第三十四條第一項規定接受當事人授與訴訟實施權，以自己之名義提起損害賠償訴訟。

第 53 條

主管機關應訂定特定目的及個人資料類別，提供公務機關及非公務機關參考使用。

第 53-1 條

對主管機關依本法所為之行政處分不服者，直接適用行政訴訟程序。

於第五十一條之一第一項、第二項公告範圍內之非公務機關，對中央目的事業主管機關或直轄市、縣（市）政府依本法所為之行政處分不服者，向主管機關提起訴願。但行政處分係由中央行政機關組織基準法所定之獨立機關所為者，直接適用行政訴

訟程序。

對本法中華民國一百十四年十月十七日修正之條文施行前依本法所為之行政處分不服，於修正施行後提起訴願者，應向主管機關為之。

本法中華民國一百十四年十月十七日修正之條文施行前已受理尚未終結之訴願事件，於修正施行後仍由原受理訴願機關依訴願法規定終結之。

第 54 條

本法中華民國九十九年五月二十六日修正公布之條文施行前，非由當事人提供之個人資料，於本法一百零四年十二月十五日修正之條文施行後為處理或利用者，應於處理或利用前，依第九條規定向當事人告知。

前項之告知，得於本法中華民國一百零四年十二月十五日修正之條文施行後首次利用時併同為之。

未依前二項規定告知而利用者，以違反第九條規定論處。

第 55 條

本法施行細則，由主管機關定之。

第 56 條

本法施行日期，由行政院定之。

本法中華民國九十九年五月二十六日修正公布之現行條文第十九條至第二十二條、第四十三條之刪除及一百十二年五月十六日修正之第四十八條，自公布日施行。

二、個人資料保護法施行細則

第 1 條

本細則依個人資料保護法（以下簡稱本法）第五十五條規定訂定之。

第 2 條

本法所稱個人，指現生存之自然人。

第 3 條

本法第二條第一款所稱得以間接方式識別，指保有該資料之公務或非公務機關僅以該資料不能直接識別，須與其他資料對照、組合、連結等，始能識別該特定之個人。

第 4 條

本法第二條第一款所稱病歷之個人資料，指醫療法第六十七條第二項所列之各款資料。

本法第二條第一款所稱醫療之個人資料，指病歷及其他由醫師或其他之醫事人員，以治療、矯正、預防人體疾病、傷害、殘缺為目的，或其他醫學上之正當理由，所為之診察及治療；或基於以上之診察結果，所為處方、用藥、施術或處置所產生之個人資料。

本法第二條第一款所稱基因之個人資料，指由人體一段去氧核糖核酸構成，為人體控制特定功能之遺傳單位訊息。

本法第二條第一款所稱性生活之個人資料，指性取向或性慣行之個人資料。

本法第二條第一款所稱健康檢查之個人資料，指非針對特定疾病進行診斷或治療之目的，而以醫療行為施以檢查所產生之資料。

本法第二條第一款所稱犯罪前科之個人資料，指經緩起訴、職權不起訴或法院判決有罪確定、執行之紀錄。

第5條

本法第二條第二款所定個人資料檔案，包括備份檔案。

第6條

本法第二條第四款所稱刪除，指使已儲存之個人資料自個人資料檔案中消失。

本法第二條第四款所稱內部傳送，指公務機關或非公務機關本身內部之資料傳送。

第7條

受委託蒐集、處理或利用個人資料之法人、團體或自然人，依委託機關應適用之規定為之。

第8條

委託他人蒐集、處理或利用個人資料時，委託機關應對受託者為適當之監督。

前項監督至少應包含下列事項：

- 一、預定蒐集、處理或利用個人資料之範圍、類別、特定目的及其期間。
- 二、受託者就第十二條第二項採取之措施。
- 三、有複委託者，其約定之受託者。
- 四、受託者或其受僱人違反本法、其他個人資料保護法律或其法規命令時，應向委託機關通知之事項及採行之補救措施。
- 五、委託機關如對受託者有保留指示者，其保留指示之事項。
- 六、委託關係終止或解除時，個人資料載體之返還，及受託者履行委託契約以儲存方式而持有之個人資料之刪除。

第一項之監督，委託機關應定期確認受託者執行之狀況，並將確認結果記錄之。

受託者僅得於委託機關指示之範圍內，蒐集、處理或利用個人資料。受託者認委託機關之指示有違反本法、其他個人資料保護法律或其法規命令者，應立即通知委託機關。

第9條

本法第六條第一項但書第一款、第八條第二項第一款、第十六條但書第一款、第十九條第一項第一款、第二十條第一項但書第一款所稱法律，指法律或法律具體明確授權之法規命令。

第10條

本法第六條第一項但書第二款及第五款、第八條第二項第二款及第三款、第十條但書第二款、第十五條第一款、第十六條所稱法定職務，指於下列法規中所定公務機關之職務：

- 一、法律、法律授權之命令。
- 二、自治條例。

三、法律或自治條例授權之自治規則。

四、法律或中央法規授權之委辦規則。

第 11 條

本法第六條第一項但書第二款及第五款、第八條第二項第二款所稱法定義務，指非公務機關依法律或法律具體明確授權之法規命令所定之義務。

第 12 條

本法第六條第一項但書第二款及第五款所稱適當安全維護措施、第十八條所稱安全維護事項、第十九條第一項第二款及第二十七條第一項所稱適當之安全措施，指公務機關或非公務機關為防止個人資料被竊取、竄改、毀損、滅失或洩漏，採取技術上及組織上之措施。

前項措施，得包括下列事項，並以與所欲達成之個人資料保護目的間，具有適當比例為原則：

- 一、配置管理之人員及相當資源。
- 二、界定個人資料之範圍。
- 三、個人資料之風險評估及管理機制。
- 四、事故之預防、通報及應變機制。
- 五、個人資料蒐集、處理及利用之內部管理程序。
- 六、資料安全管理及人員管理。
- 七、認知宣導及教育訓練。
- 八、設備安全管理。
- 九、資料安全稽核機制。
- 十、使用紀錄、軌跡資料及證據保存。
- 十一、個人資料安全維護之整體持續改善。

第 13 條

本法第六條第一項但書第三款、第九條第二項第二款、第十九條第一項第三款所稱當事人自行公開之個人資料，指當事人自行對不特定人或特定多數人揭露其個人資料。

本法第六條第一項但書第三款、第九條第二項第二款、第十九條第一項第三款所稱已合法公開之個人資料，指依法律或法律具體明確授權之法規命令所公示、公告或以其他方式公開之個人資料。

第 14 條

本法第六條第一項但書第六款、第十一條第二項及第三項但書所定當事人書面同意之方式，依電子簽章法之規定，得以電子文件為之。

第 15 條

本法第七條第二項所定單獨所為之意思表示，如係與其他意思表示於同一書面為之者，蒐集者應於適當位置使當事人得以知悉其內容並確認同意。

第 16 條

依本法第八條、第九條及第五十四條所定告知之方式，得以言詞、書面、電話、簡訊、電子郵件、傳真、電子文件或其他足以使當事人知悉或可得知悉之方式為之。

第 17 條

本法第六條第一項但書第四款、第九條第二項第四款、第十六條但書第五款、第十九條第一項第四款及第二十條第一項但書第五款所稱無從識別特定當事人，指個人資料以代碼、匿名、隱藏部分資料或其他方式，無從辨識該特定個人者。

第 18 條

本法第十條但書第三款所稱妨害第三人之重大利益，指有害於第三人個人之生命、身體、自由、財產或其他重大利益。

第 19 條

當事人依本法第十一條第一項規定向公務機關或非公務機關請求更正或補充其個人資料時，應為適當之釋明。

第 20 條

本法第十一條第三項所稱特定目的消失，指下列各款情形之一：

- 一、公務機關經裁撤或改組而無承受業務機關。
- 二、非公務機關歇業、解散而無承受機關，或所營事業營業項目變更而與原蒐集目的不符。
- 三、特定目的已達成而無繼續處理或利用之必要。
- 四、其他事由足認該特定目的已無法達成或不存在。

第 21 條

有下列各款情形之一者，屬於本法第十一條第三項但書所定因執行職務或業務所必須：

- 一、有法令規定或契約約定之保存期限。
- 二、有理由足認刪除將侵害當事人值得保護之利益。
- 三、其他不能刪除之正當事由。

第 22 條

本法第十二條所稱適當方式通知，指即時以言詞、書面、電話、簡訊、電子郵件、傳真、電子文件或其他足以使當事人知悉或可得知悉之方式為之。但需費過鉅者，得斟酌技術之可行性及當事人隱私之保護，以網際網路、新聞媒體或其他適當公開方式為之。

依本法第十二條規定通知當事人，其內容應包括個人資料被侵害之事實及已採取之因應措施。

第 23 條

公務機關依本法第十七條規定為公開，應於建立個人資料檔案後一個月內為之；變更時，亦同。公開方式應予以特定，並避免任意變更。

本法第十七條所稱其他適當方式，指利用政府公報、新聞紙、雜誌、電子報或其他可供公眾查閱之方式為公開。

第 24 條

公務機關保有個人資料檔案者，應訂定個人資料安全維護規定。

第 25 條

本法第十八條所稱專人，指具有管理及維護個人資料檔案之能力，且足以擔任機關之個人資料檔案安全維護經常性工作之人員。

公務機關為使專人具有辦理安全維護事項之能力，應辦理或使專人接受相關專業之教育訓練。

第 26 條

本法第十九條第一項第二款所定契約或類似契約之關係，不以本法修正施行後成立者為限。

第 27 條

本法第十九條第一項第二款所定契約關係，包括本約，及非公務機關與當事人間為履行該契約，所涉及必要第三人之接觸、磋商或聯繫行為及給付或向其為給付之行為。

本法第十九條第一項第二款所稱類似契約之關係，指下列情形之一者：

一、非公務機關與當事人間於契約成立前，為準備或商議訂立契約或為交易之目的，所進行之接觸或磋商行為。

二、契約因無效、撤銷、解除、終止而消滅或履行完成時，非公務機關與當事人為行使權利、履行義務，或確保個人資料完整性之目的所為之連繫行為。

第 28 條

本法第十九條第一項第七款所稱一般可得之來源，指透過大眾傳播、網際網路、新聞、雜誌、政府公報及其他一般人可得知悉或接觸而取得個人資料之管道。

第 29 條

依本法第二十二條規定實施檢查時，應注意保守秘密及被檢查者之名譽。

第 30 條

依本法第二十二條第二項規定，扣留或複製得沒入或可為證據之個人資料或其檔案時，應掣給收據，載明其名稱、數量、所有人、地點及時間。

依本法第二十二條第一項及第二項規定實施檢查後，應作成紀錄。

前項紀錄當場作成者，應使被檢查者閱覽及簽名，並即將副本交付被檢查者；其拒絕簽名者，應記明其事由。

紀錄於事後作成者，應送達被檢查者，並告知得於一定期限內陳述意見。

第 31 條

本法第五十二條第一項所稱之公益團體，指依民法或其他法律設立並具備個人資料保護專業能力之公益社團法人、財團法人及行政法人。

第 32 條

本法修正施行前已蒐集或處理由當事人提供之個人資料，於修正施行後，得繼續為處理及特定目的內之利用；其為特定目的外之利用者，應依本法修正施行後之規定

為之。

第 33 條

本細則施行日期，由法務部定之。

三、醫院個人資料檔案安全維護計畫實施辦法

第 1 條

本辦法依個人資料保護法（以下簡稱本法）第二十七條第三項規定訂定之。

第 2 條

本辦法適用範圍，為醫院蒐集、處理及利用之病歷或醫療個人資料。

第 3 條

本辦法所稱主管機關：在中央為衛生福利部；在直轄市為直轄市政府；在縣（市）為縣（市）政府。

第 4 條

本辦法用詞，定義如下：

- 一、醫院：指總床數達一百床以上之私立醫院、醫療法人醫院及其他法人附設醫院。
 - 二、所屬人員：指醫院執行業務之過程，接觸個人資料之人員。
 - 三、專責人員：指醫院指定，負責規劃、訂定、修正及執行個人資料檔案安全維護計畫（以下簡稱安全維護計畫），及業務終止後個人資料處理方法與其他相關事項，並應定期向醫院提出報告之人員。
 - 四、查核人員：指醫院指定，負責評核安全維護計畫執行情形及成效之人員。
- 前項第三款與第四款人員，不得為同一人。

第 5 條

醫院應依本辦法規定訂定安全維護計畫，其應載明事項如下：

- 一、個人資料蒐集、處理及利用之內部管理程序。
- 二、個人資料之範圍及項目。
- 三、人員管理及教育訓練。
- 四、設備安全管理。
- 五、個人資料安全事故之預防、通報及應變機制。
- 六、使用紀錄、軌跡資料及證據保存。
- 七、業務終止後，個人資料處理方法。
- 八、個人資料安全維護之整體持續改善方案。
- 九、資料安全管理及稽核機制。

前項安全維護計畫，應報直轄市、縣（市）主管機關備查；修正時，亦同。

第 6 條

前條安全維護計畫，應依醫院業務規模及特性，衡酌經營資源之合理分配，規劃、訂定、檢討或修正安全維護措施，落實個人資料檔案之安全維護及管理，防止個人

資料被竊取、竄改、毀損、滅失或洩漏。

第 7 條

醫院訂定第五條第一項第一款個人資料蒐集、處理及利用之內部管理程序及第二款個人資料之範圍及項目時，應確認蒐集個人資料之特定目的及其必要性，界定所蒐集、處理及利用個人資料之類別或範圍，並定期清查所保有之個人資料現況。

醫院經定期檢視，發現有非屬特定目的必要範圍內之個人資料或特定目的消失、期間屆滿而無保存必要者，應依第五條第一項第八款及醫療法第七十條規定，刪除、銷毀、停止蒐集、處理、利用或為其他適當之處置。

第 8 條

醫院於蒐集個人資料時，應符合前條第一項所定之類別及範圍。

醫院於傳輸個人資料時，應採取必要保護措施；國際傳輸電子病歷時，並應符合醫療機構電子病歷製作及管理辦法之規定。

第 9 條

醫院於蒐集個人資料時，應遵守本法第八條及第九條有關告知義務之規定，並依直接蒐集或間接蒐集，分別訂定告知方式、內容及注意事項，要求所屬人員確實辦理。前項告知，其他法規另有規定者，從其規定。

第 10 條

醫院委託他人蒐集、處理或利用個人資料之全部或一部時，應對受託人依本法施行細則第八條規定為適當之監督，並於委託契約或相關文件中，明確約定其內容。

第 11 條

醫院應依第五條第一項第一款規定，對其所屬人員採取下列措施：

- 一、依據業務作業需要，建立管理機制，設定所屬人員權限，控管其接觸個人資料，並定期確認權限內容之必要性及適當性。
- 二、檢視各相關業務之性質，規範個人資料蒐集、處理、利用及其他相關流程之負責人員。
- 三、要求所屬人員妥善保管個人資料之儲存媒介物，並約定保管及保密義務。
- 四、取消所屬人員離職時之存取權限，並要求將執行業務所持有之文件、資料，辦理交接，不得攜離使用。

第 12 條

醫院應依第五條第一項第三款規定，使所屬人員明瞭個人資料保護相關法令規定、責任範圍、作業程序及應遵守之相關措施。

第 13 條

醫院應依第五條第一項第四款規定，對所持有之個人資料檔案，設置必要之安全設備及防護措施。

前項安全設備及防護措施，應包括下列事項：

- 一、訂定各類設備或儲存媒體之使用規範。
- 二、個人資料內容於蒐集、處理或利用時，訂定並採取適當之加密措施或配置安全

防護系統。

三、個人資料有備份之需要時，訂定備份機制、管理及保護程序。

四、訂定資料之銷毀程序，包括電腦、自動化機器或其他儲存媒介物於報廢、汰換或轉作其他用途時，確保個人資料完全移除或清除，無洩漏之虞。

第 13-1 條

前條個人資料檔案使用資通訊系統蒐集、處理或利用時，應訂定並採取下列資訊安全措施：

一、使用者身分確認及保護措施。

二、個人資料顯示之隱碼措施及使用時機。

三、網際網路傳輸之安全加密措施。

四、個人資料檔案及資料庫之存取控制與保護監控措施。

五、防止外部網路入侵措施。

六、非法或異常使用行為之監控及因應措施。

前項第五款及第六款措施，應定期演練及檢討改善。

第 14 條

醫院應依第五條第一項第五款規定，於發生個人資料被竊取、洩漏、竄改、毀損、滅失或其他侵害事故時迅速處理，以保護當事人之權益。

前項處理應包括下列事項：

一、採取適當之措施，控制事故對當事人造成之損害。

二、查明事故發生原因及損害狀況，以適當方式通知當事人或其法定代理人，並於發現事故時起七十二小時內，以書面通報直轄市、縣（市）主管機關及副知中央主管機關。

三、研議並採取避免事故再度發生之改進措施。

直轄市、縣（市）主管機關就所轄醫院個人資料發生第一項事故之完整處理情形，應按季通報中央主管機關。

直轄市、縣（市）主管機關接受第二項通報後，得依本法第二十二條至第二十五條規定，對該醫院為適當之監督管理措施；中央主管機關認有必要時，得督導直轄市、縣（市）主管機關對於該醫院之相關監督管理機制。

第二項第二款通報紀錄格式及第三項按季通報紀錄格式，規定如附件一及附件二。

第 15 條

醫院應依第五條第一項第六款規定，採行適當措施，留存個人資料使用紀錄、自動化機器設備之軌跡資料或其他相關之證據資料，並於必要時提供說明。

前項紀錄與資料，應至少留存六個月。但法令另有規定者，不在此限。

第 16 條

醫院應依第五條第一項第七款規定，對業務終止後，其保有個人資料，依下列方式為之，並製作紀錄：

一、銷毀：銷毀之方法、時間、地點及證明。

二、移轉：移轉之原因、對象、方法、時間、地點及受移轉對象得保有該項個人資料之合法依據。

三、其他刪除、停止處理或利用個人資料：刪除、停止處理或利用之方法、時間或地點。

前項紀錄，應至少留存五年。但法令另有規定者，不在此限。

第 17 條

醫院應依第五條第一項第八款規定，參酌安全維護計畫執行狀況、技術發展、法令依據修正及其他因素，檢視所定安全維護計畫之合宜性，必要時應予修正。

第 18 條

查核人員應每年評核安全維護計畫之執行情形及成效，並將評核結果，向醫院提出報告。

醫院應依據前項評核結果，責成專責人員檢討、修正安全維護計畫之執行事項。

直轄市、縣（市）主管機關應定期查核第一項評核結果。

第 19 條

本辦法於公立醫院，準用之。

第 20 條

本辦法自發布後六個月施行。

本辦法修正條文自發布日施行。

四、醫療機構電子病歷製作及管理辦法

第一章 總則

第 1 條

本辦法依醫療法（以下簡稱本法）第六十九條規定訂定之。

第 2 條

醫療機構以電子文件方式製作及貯存之病歷（以下簡稱電子病歷），符合本辦法之規定者，得免另以書面方式製作。

第 3 條

醫療機構實施電子病歷者，應建置電子病歷資訊系統（以下簡稱系統），並具備下列管理機制：

一、標準作業機制：系統建置、維護及稽核之標準作業程序。

二、權限管控機制：電子病歷製作、存取、增刪、查閱、複製、傳輸及其他使用權限之管控。

三、緊急應變機制：系統故障之預防、通報、應變、復原及其他緊急應變措施。

四、系統安全機制：確保系統安全、時間正確、系統備援與資料備份及其他保護措施。

五、傳輸加密機制：網路傳輸電子病歷，使用國際標準組織通用之加密機制。

六、安全事故處理機制：因應系統遭侵入、資料洩漏、毀損或其他安全事故之預防、通報與應變、檢討及修正措施。

執行前項各款管理機制，應製作紀錄，妥善保存至少五年。

第 4 條

前條第一項第四款系統安全機制之其他保護措施，應包括下列事項：

一、使用者身分之確認。

二、個人資料顯示之隱碼或其他適當保護措施。

三、系統開發、上線、維護及應用軟體之驗證確認程序。

四、系統使用及資料存取之監控措施。

五、網路入侵系統之防範措施。

六、非法或異常使用之因應措施。

第 5 條

醫療機構發生第三條第一項第六款安全事故時，並應以個人資料保護法施行細則第二十二條所定方式及內容，通知當事人或其法定代理人。

前項安全事故影響醫療機構營運或當事人權益時，醫療機構應於知悉事故發生起七十二小時內通報直轄市、縣（市）主管機關。

第 6 條

第三條第一項系統，醫療機構得委託大專校院、依法登記或立案之法人、機構或團體（以下併稱受託機構）建置及管理之，並由醫療機構負本法及本辦法規定之責任。

前項醫療機構之委託，應訂定書面契約。但有下列情形之一者，得免訂定書面契約：

一、委託所屬醫療法人或其他法人之其他附設醫院。

二、委託所屬學校之其他附設醫院。

三、委託所屬機關設立之其他醫院。

第一項受託機構，應通過中央主管機關認可之資訊安全標準驗證，並有證明文件。

第 7 條

前條第二項契約，應載明下列事項：

一、委託事項之範圍。

二、受託機構之權利義務。

三、受託機構應遵行第三條至第四條、第八條、第十三條至第十六條規定。

- 四、受託機構利用非自行開發之系統或資源者，其來源及授權證明。
- 五、病人隱私保障及資料保密與安全維護之措施。
- 六、受託機構遵行委託機構訂定之標準作業程序、風險管理、內部控制及稽核制度。
- 七、雙方終止及解除契約之事由及資料處理機制。
- 八、受託機構就委託事項，同意主管機關於指定期間內取得相關文件、資料或報告。
- 九、受託機構就委託事項，發現資通安全異常或缺失時，應立即通知委託機構。
- 十、受託機構就委託事項，不得再委託第三人為之。但經醫療機構同意，並於契約載明再委託事項、期間及再受託者，且不免除原受託機構之義務時，不在此限。
- 十一、其他中央主管機關指定之事項。

第 8 條

醫療機構就系統資料之蒐集、處理與利用及資料庫之使用，運用雲端服務或委託受託機構提供雲端服務時，應依下列規定辦理：

- 一、採取適當風險管控措施。
 - 二、採取避免醫療業務中斷措施。
 - 三、對雲端服務業者進行監督，並得視需要，委託受託機構或其他專業機構協助監督。
 - 四、停止或終止雲端服務時，資料移轉回委託機構或其他雲端服務業者之機制。
- 前項雲端服務之資料儲存地點，應設置於我國境內。但因特殊情形，經中央主管機關核准者，不在此限。
- 第一項提供雲端服務者，應通過中央主管機關認可之資訊安全標準驗證，並有證明文件。

第 9 條

醫療機構實施電子病歷者，應敘明開始實施之日期及範圍，並檢附第六條第二項契約及第三項驗證通過之證明文件，於實施之日起十五日內報直轄市、縣（市）主管機關備查；變更實施範圍、受託機構或停止實施時亦同。

第 10 條

醫療機構實施電子病歷者，於接受醫院評鑑或申報全民健康保險給付時，醫院評鑑或全民健康保險之主管、主辦機關非有特殊理由，不得要求其提供電子病歷之列印或影印本。

第二章 病歷製作及簽章

第 11 條

醫療機構製作電子病歷，應符合下列規定：

- 一、輸入識別碼或其他識別方式，經電腦系統確認其身分及權限相符後，始得進行。

二、增刪電子病歷時，應能與增刪前明顯辨識，並保存個人使用紀錄及日期資料。

三、依本法第六十八條第一項所為之簽名或蓋章，以電子簽章為之。

四、病歷製作後，應於二十四小時內完成電子簽章。

五、電子簽章後，應進行存檔及備份。

醫事人員因故無法於前項第四款時限內完成電子簽章時，應由醫療機構採用醫事機構憑證簽章代替；除有特殊情形外，醫事人員應於事後完成補簽。

第 12 條

電子簽章，除前條第二項規定外，應憑中央主管機關核發之醫事人員憑證為之。但醫療機構訂有符合電子簽章法規定之其他簽章方式者，得依其方式為之。

前條第二項醫事機構憑證與前項醫事人員憑證及其附卡、備用卡之核發、換發、補發，由中央主管機關自行或委託民間團體辦理，並得收取費用；其費額，依醫事憑證收費標準之規定。

第三章 儲存、銷毀及交換

第 13 條

本法第七十條第一項所定病歷保存期間內，電子病歷之存取、增刪、查閱、複製與其他相關事項，及其執行人員、時間與內容，應保存完整紀錄。

第 14 條

醫療機構依本法第七十條第二項規定，將電子病歷移轉由承接者保存時，應將移轉之原因、對象、方法、時間、地點及受移轉對象得保有該電子病歷之合法依據，製作紀錄交由承接者至少保存五年。

第 15 條

醫療機構儲存電子病歷之電腦、自動化機器或其他電子媒介物（以下併稱儲存媒體），於報廢、汰換或轉作其他用途時，應採取適當措施，確保電子病歷資料完全移除或清除，而無洩漏之虞；儲存媒體無法完全移除、清除或可事後還原資料者，應進行實體破壞，使其無法使用。

第 16 條

醫療機構依本法第七十條第二項、第四項銷毀電子病歷時，應記錄銷毀之人員、方法、時間及地點，並保存紀錄至少五年；委外銷毀時，亦同。

執行前項銷毀，應派人全程監視確認已完全銷毀，並拍照存證。

第 17 條

醫療機構得將下列資料，以電子方式轉錄為電子檔案保存；轉錄後，應檢視電子檔

案內容與原件相符，並以醫事機構憑證簽章封存後，報直轄市、縣（市）主管機關備查，始視同電子病歷：

一、依本法或其他醫療法規規定，應以書面同意且併同病歷保存之文件。

二、醫療機構電子病歷實施前既有之紙本病歷。

三、其他依法令規定應併同病歷保存之文件、資料。

前項原件，得免以書面方式保存，且不受本法第七十條第一項保存期間之限制。

醫療機構銷毀第一項原件紙本文件、資料時，應記錄銷毀之明細、方法、時間及地點，並保存紀錄至少五年。

第 18 條

中央主管機關或經中央主管機關認可之機關及公、私立機構，得設置電子病歷交換平臺，供醫療機構進行跨機構電子病歷交換或利用。

醫療機構進行電子病歷交換或利用時，應以前項平臺為之。但第六條第二項但書各款醫療機構使用同一系統者，不在此限。

第一項電子病歷交換格式、簽章與時戳及其他相關事項，由中央主管機關公告之。

第 19 條

醫療機構依前條第一項交換平臺為電子病歷交換或利用時，應經病人同意，始得為之。但病人情況緊急，無法取得或未能及時取得同意者，不在此限。

前項病人為胎兒時，應得其母同意；為限制行為能力人或受輔助宣告之人時，應得其本人及法定代理人或輔助人同意；為無行為能力人或受監護宣告之人時，應得其法定代理人或監護人同意。

第一項病人為無意思能力之成年人，未能依前項規定辦理時，應取得親屬或關係人之同意。

第四章 附則

第 20 條

依本法或其他醫療法規規定，應以書面同意且併同病歷保存之文件，得依電子簽章法之規定，以電子方式為之；並得應相對人要求，交付紙本或以電子方式提供。

第 21 條

電子病歷個人資料之保護，本辦法未規定者，依個人資料保護法、醫院個人資料檔案安全維護計畫實施辦法及其他相關法令之規定。

第 22 條

本辦法中華民國一百十一年七月十八日修正施行前，醫療機構已委託受託機構建置、管理系統者，應自修正施行之日起一年內，依第九條規定辦理。

交付日期：115年3月27日

交付版次：v.1版

本辦法中華民國一百一十一年七月十八日修正施行前，機關及公、私立機構已建置之電子病歷交換平臺，應自修正施行之日起一年內，取得第十八條第一項之認可，並符合第十八條第三項規定。

第 23 條

本辦法自發布日施行。